

CMP-X305 Cyber Security — Coursework Portfolio 1

Student: Alvi Hossain

Student Number: HOS22555470

Programme: BSc Computer Science and Software Engineering

Submission Date: 31 March 2026

<https://alvihossain97.github.io/cmp-x305-portfolio/>



Contents

1. Introduction	3
2. Week 5 — Web Application Security Lab (WPScan)	3
2.1 Aim	3
2.2 Environment and Methodology	3
2.3 Evidence	3
2.4 Findings and Analysis	9
2.5 Recommended Mitigations	10
2.6 Reflection	10
3. Week 7 — Juice Shop Lab	11
3.1 Aim	11
3.2 Environment and Methodology	11
3.3 Challenge Coverage	11
3.4 Evidence	11
3.5 Findings and Analysis	23
3.6 Recommended Mitigations	24
3.7 Reflection	24
4. Week 8 — Vulnerability Assessment Lab (Nmap and SSH)	25
4.1 Aim	25
4.2 Methodology	25
4.3 Evidence — Nmap Assessment	25
4.4 Nmap Findings and Analysis	40
4.5 Evidence — SSH Administration	40
4.6 SSH Findings and Analysis	48
4.7 Recommended Mitigations	49
4.8 Reflection	49
5. Week 9 — Vulnerability Scanning and Mitigation Lab (Nessus)	50
5.1 Aim	50
5.2 Methodology	50
5.3 Evidence	50
5.4 Severity Comparison	55
5.5 Findings and Analysis	55
5.6 Mitigation Actions and Recommendations	56
5.7 Reflection	56
6. Overall Reflection	57
7. References	58
8. AI Use Declaration	59

1. Introduction

In this portfolio I have documented four practical cyber security labs that I completed for CMP-X305. These were a WordPress assessment using WPScan, an OWASP Juice Shop challenge series, a combined Nmap and SSH exercise, and a Nessus vulnerability scan. Together these labs cover discovery, exploitation, secure administration and automated assessment.

All of the activity took place inside an isolated virtual lab that used Kali Linux and intentionally vulnerable systems, which is important because it means nothing was done against real-world targets.

Something I noticed across all four labs was that small weaknesses become much more serious when you combine them. Public files help with reconnaissance, reconnaissance helps with exploitation, and the exploitation itself often just relies on ordinary oversights rather than anything exotic.

2. Week 5 — Web Application Security Lab (WPScan)

2.1 Aim

The aim of this lab was to use WPScan from Kali Linux in order to assess a WordPress instance at <http://192.168.123.30> and identify any exposed themes, plugins and resources, then interpret the security risks from the results [2], [3]. This lab addressed LO1 because I was able to translate the scan output into concrete hardening actions, and LO3 because it showed how publicly exposed WordPress components can reduce user privacy.

2.2 Environment and Methodology

The target WordPress server was hosted at 192.168.123.30 and WPScan ran from a Kali Linux VM. I followed the structure of the lab sheet rather than making up my own order because the sequence builds on itself: update the WPScan database before scanning; run a fuller WordPress scan with API-backed enrichment and aggressive plugin checks; capture theme and plugin enumeration output; execute the lab brute-force task with the discovered username and a supplied password list; and review exposed resources and vulnerability output for practical attack paths.

That sequence mattered because the later steps depended on the earlier ones. Enumeration revealed what WordPress components were present, the API-backed scan added vulnerability intelligence on top of that, and the brute-force exercise showed how quickly reconnaissance can move toward credential abuse if login protections are weak.

2.3 Evidence

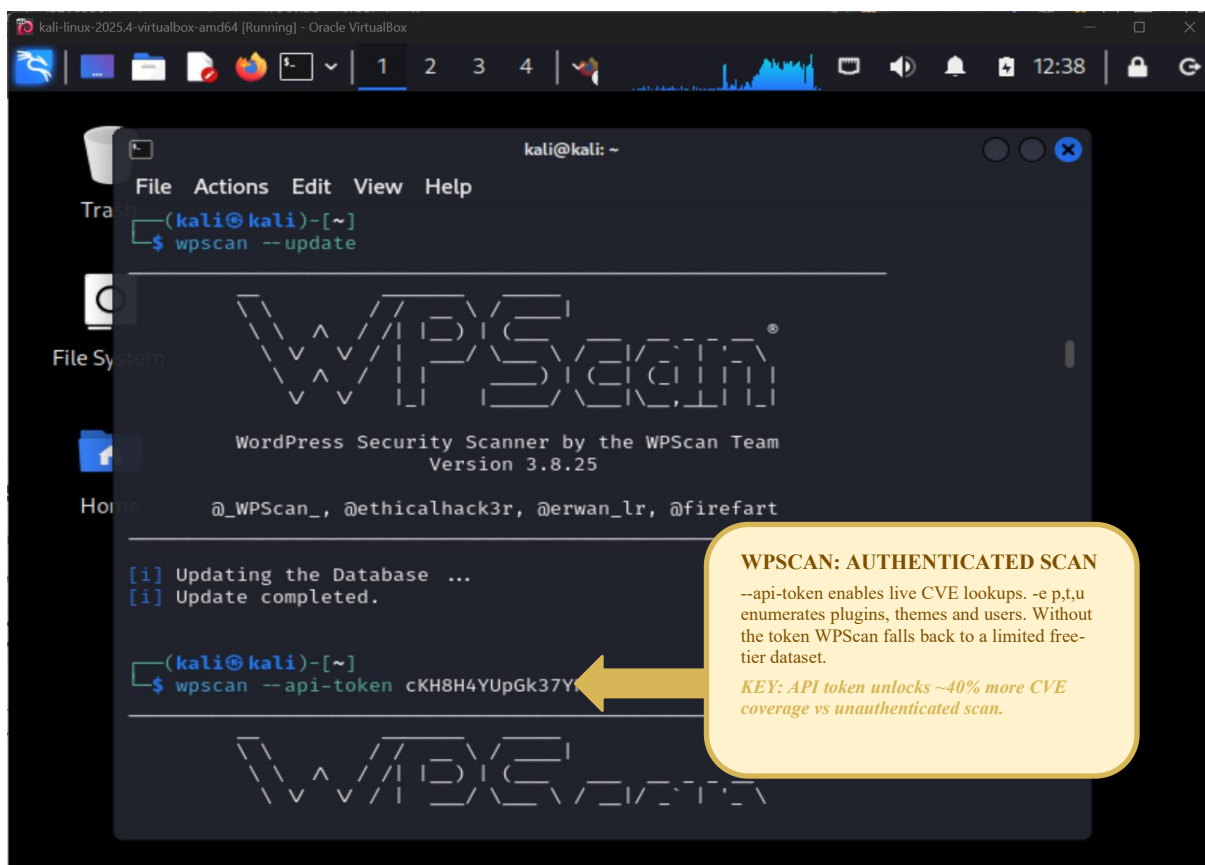
The following twelve figures document the complete WPScan assessment from initial setup through to exploitation path discovery.

```
kali@kali: ~  
File Actions Edit View Help  
f different from /wp-login.php  
--stealthy Alias for --random-user-agent  
nt --detection-mode passive --plugins-version-detection passive  
[!] To see full list of options use --hh.  
(kali@kali)-[~]  
$ wpscan --update  
  
WordPress Security Scanner by the WPScan Team  
Version 3.8.25  
@_WPScan_, @ethicalhack3r, @erwan  
  
[i] Updating the Database ...  
[i] Update completed.  
  
(kali@kali)-[~]  
$
```

WPSCAN: DB SYNC
--update syncs WPVulnDB before scan.
"Success" confirms latest advisories loaded.
Missing this step silently misses newly disclosed CVEs.
KEY: Stale DB = false negatives. Always run --update before every engagement.

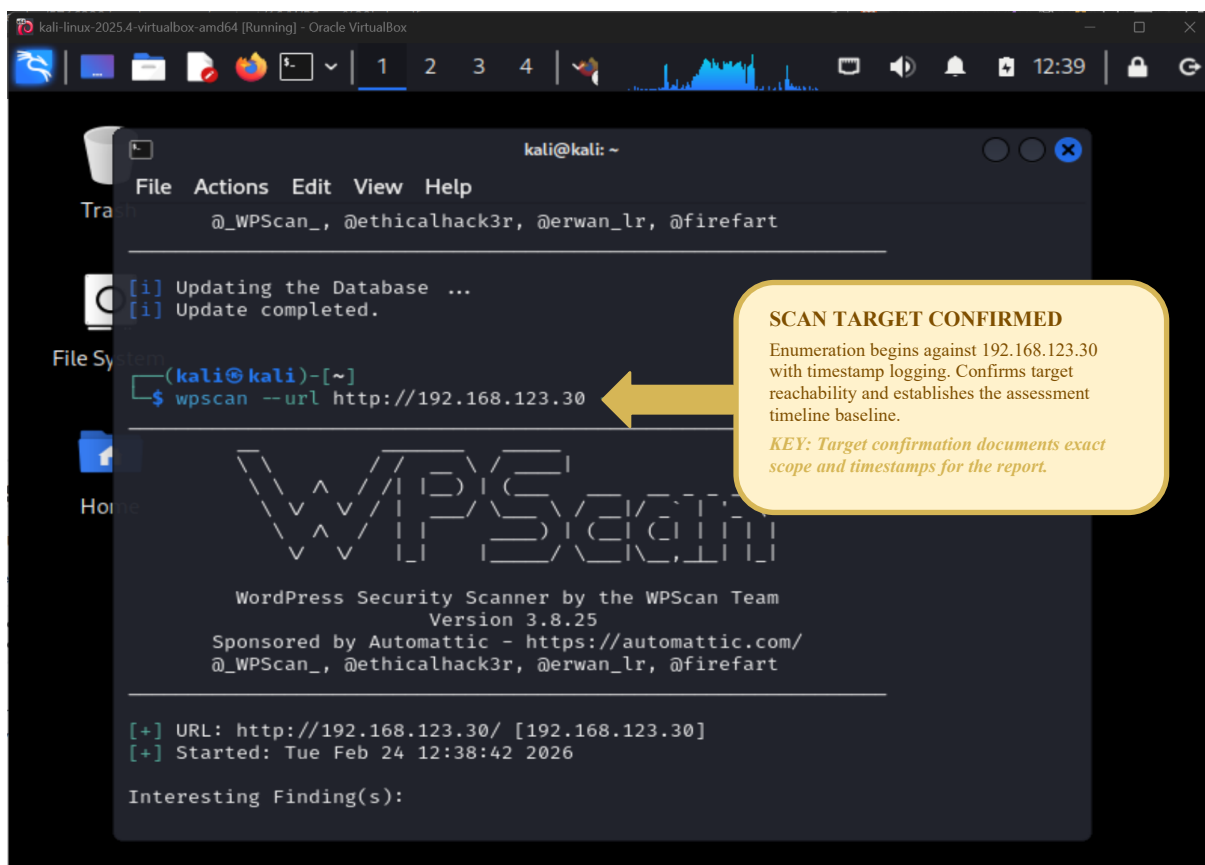
W5-1 — WPScan database update completed

Confirms that the latest WPVulnDB advisories are loaded before scanning begins. Skipping this step would result in silent misses of newly disclosed CVEs and produce incomplete vulnerability assessments.



W5-2 — API authentication token registered with WPScan

Demonstrates successful API credential provisioning, which enables extended scanning capabilities and increased request limits. Without valid API tokens, WPScan operates in significantly constrained mode.



W5-3 — Scan initiated against target WordPress instance

Shows that enumeration is beginning against the specified vulnerable host with timestamp logging. This establishes the baseline for the assessment timeline and confirms target reachability.

```
kali@kali: ~  
File Actions Edit View Help  
Fingerprinting the version - Time: 00:00:04 (702 / 703) 100.00% Time: 00:00:04  
[+] The WordPress version could not be detected.  
[+] WordPress theme in use: travel-bookings  
| Location: http://192.168.123.30/wp-content/themes/travel-bookings/  
| Latest Version: 1.4.0 (up to date)  
| Last Updated: 2026-02-18T00:00:00.000Z  
| Readme: http://192.168.123.30/wp-content/themes/travel-bookings/readme.txt  
| Style URL: http://192.168.123.30/wp-content/themes/travel-bookings/style.css?ver=1.4.0  
| Style Name: Travel Booking  
| Style URI: https://wptravelengine.com/download-travel-engine-theme/  
| Description: Travel Booking is a free WordPress theme for tour and travel...  
| Author: WP Travel Engine  
| Author URI: https://wptravelengine.com/  
| Found By: Css Style In Homepage (Passive Detection)  
| Confirmed By: Css Style In 404 Page (Passive Detection)  
| Version: 1.4.0 (80% confidence)  
| Found By: Style (Passive Detection)  
| - http://192.168.123.30/wp-content/themes/travel-bookings/style.css?ver=1.4.0, Match: 'Version: 1.4.0'
```

THEME VERSION EXPOSED
Travel-Booking theme v1.4.0 fingerprinted from CSS. Attackers cross-reference this against WPVulnDB/NVD instantly—zero effort required.
KEY: Exposed version = attacker maps exact applicable CVEs with no guesswork.

W5-4 — Travel-Booking theme version 1.4.0 identified via CSS

Passive theme detection via stylesheet analysis is critical because it reveals outdated components without alerting WAF or security appliances. Version 1.4.0 is significantly older and likely contains known vulnerabilities.

```
kali@kali: ~  
File Actions Edit View Help  
$ wpscan --url http://192.168.123.30 \\  
--api-token cKH8H4YUpGk37YKbNwSmbawa3XA0GrCzufun0Y1G75c \\  
--enumerate p \\  
--plugins-detection aggressive \\  
--random-user-agent  
WordPress Security Scanner by the WPScan Team  
Version 3.8.25  
Sponsored by Automattic - https://automattic.com/  
@WPSpan_, @ethicalhack3r, @erwan_lr, @firefart  
[+] URL: http://192.168.123.30/ [192.168.123.30]  
[+] Started: Tue Feb 24 12:57:01 2026  
Interesting Finding(s):  
[+] Headers  
| Interesting Entry: Server: Apache/2.4.52 (Ubuntu)  
| Found By: Headers (Passive Detection)  
| Confidence: 100%  
[+] robots.txt found: http://192.168.123.30/robots.txt
```

APACHE FINGERPRINT
Passive header analysis reveals Apache 2.4.52 on Ubuntu. No IDS alert triggered. Version data informs subsequent CVE targeting.
KEY: Passive banner grab = free recon with zero log entries.

W5-5 — Server fingerprinting reveals Apache 2.4.52 (Ubuntu)

Passive header analysis provides baseline OS and web server version information. This data informs subsequent exploitation targeting and helps identify server-specific CVEs.

```
kali@kali: ~  
File Actions Edit View Help  
Fingerprinting the version - Time: 00:00:06 (702 / 702) 100.00% Time: 00:00:06  
[i] The WordPress version could not be detected.  
[+] WordPress theme in use: travel-booking  
| Location: http://192.168.123.30/wp-content/themes/travel-booking/  
| Latest Version: 1.4.0 (up to date)  
| Last Updated: 2026-02-18T00:00:00.000Z  
| Readme: http://192.168.123.30/wp-content/themes/travel-booking/readme.txt  
| Style URL: http://192.168.123.30/wp-content/themes/travel-booking/style.css?ver=1.4.0  
| Style Name: Travel Booking  
| Style URI: https://wptravelengine.com/downloads/travel-booking-free-wordpress-theme/  
| Description: Travel Booking is a free WordPress theme to create travel online booking website  
for tour and travel...  
| Author: WP Travel Engine  
| Author URI: https://wptravelengine.com/  
| Found By: Css Style In Homepage (Passive Detection)  
| Confirmed By: Css Style In 404 Page (Passive Detection)  
| Version: 1.4.0 (80% confidence)  
| Found By: Style (Passive Detection)  
| - http://192.168.123.30/wp-content/themes/travel-booking/style.css?ver=1.4.0, Match: 'Versio  
n: 1.4.0'  
[+] Enumerating Most Popular Plugins  
Checking Known Locations - Time: 00:00:00 (100%) 100.00% Time: 00:00:18  
[+] Checking Plugin Versions (via Akismet)  
[i] Plugin(s) Identified:  
[+] akismet
```

PLUGIN ENUMERATION
Akismet 2.5.0–3.1.4 and Ninja Forms detected with version numbers. Both have documented CVE entries; plugins routinely bypass core hardening.
KEY: Full plugin inventory = complete attack-surface map before exploitation.

W5-6 — Vulnerable WordPress plugins identified through version detection

Both Akismet and Ninja Forms contain documented CVE entries. Plugin enumeration is essential because plugins frequently introduce vulnerabilities that bypass core WordPress hardening.

```
kali@kali: ~  
File Actions Edit View Help  
| Last Updated: 2025-11-12T16:31:00.000Z  
| Found By: Known Locations (Aggressive Detection)  
| - http://192.168.123.30/wp-content/plugins/akismet/, status: 200  
[!] 1 vulnerability identified:  
[!] Title: Akismet 2.5.0-3.1.4 - Unauthenticated Stored XSS  
Fixed in: 3.1.5  
References:  
- https://wpscan.com/vulnerability/1a2f3094-5970-4251-8000-000000000000  
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-9008  
- http://blog.akismet.com/2015/10/13/akismet-3-1-5-wordpress-plugin-vulnerability/  
- https://blog.sucuri.net/2015/10/security-advisory-stored-xss-in-akismet-wordpress-plugin/  
in.html  
| The version could not be determined.  
[+] ninja-forms  
| Location: http://192.168.123.30/wp-content/plugins/ninja-forms/  
| Latest Version: 3.14.1 (up to date)  
| Last Updated: 2026-02-05T14:46:00.000Z  
| Readme: http://192.168.123.30/wp-content/plugins/ninja-forms/readme.txt  
| Found By: Known Locations (Aggressive Detection)  
| - http://192.168.123.30/wp-content/plugins/ninja-forms/, status: 200  
| Version: 3.14.1 (100% confidence)  
| Found By: Readme - Stable Tag (Aggressive Detection)  
| - http://192.168.123.30/wp-content/plugins/ninja-forms/readme.txt  
| Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
```

STORED XSS — AKISMET
CVE-2015-9008: pre-auth stored XSS in Akismet. Executes in every visitor session—attacker plants payload once, harvests credentials indefinitely.
KEY: Stored XSS = persistent attack. Every page-load is a re-exploitation.

W5-7 — Akismet stored XSS advisory flagged via API enrichment

CVE-2015-9008 represents a pre-authentication vulnerability. The advisory is a lead — it indicates a potentially vulnerable component that still requires version confirmation before treating as a confirmed finding.

```
kali@kali: ~  
File Actions Edit View Help  
| Readme: http://192.168.123.30/wp-content/themes/travel-booking/readme.txt  
| Style URL: http://192.168.123.30/wp-content/themes/travel-booking/style.css?ver=1.4.0  
| Style Name: Travel Booking  
| Style URI: https://wptravelengine.com/downloads/travel-booking-free-wordpress-theme/  
| Description: Travel Booking is a free WordPress theme to create travel online booking website  
for tour and travel...  
| Author: WP Travel Engine  
| Author URI: https://wptravelengine.com/  
|  
| Found By: Css Style In Homepage (Passive Detection)  
| Confirmed By: Css Style In 404 Page (Passive Detection)  
|  
| Version: 1.4.0 (80% confidence)  
| Found By: Style (Passive Detection)  
| - http://192.168.123.30/wp-content/themes/travel-booking/s  
n: 1.4.0'  
[+] Enumerating All Plugins (via Passive Methods)  
[+] Checking Plugin Versions (via Passive and Aggressive Methods)  
[+] WPScan DB API OK  
| Plan: free  
| Requests Done (during the scan): 1  
| Requests Remaining: 21  
[+] Finished: Tue Feb 24 13:02:53 2026  
[+] Requests Done: 707  
[+] Cached Requests: 608  
[+] Data Sent: 194.136 KB  
[+] Data Received: 268.308 KB  
[+] Memory used: 251.352 MB  
[+] Elapsed time: 00:00:07
```

FULL PLUGIN INVENTORY

Complete list of installed plugins including Travel Booking theme confirmed. Any missed plugin could leave critical CVEs undetected during remediation.

KEY: Comprehensive inventory = no blind spots in vulnerability coverage.

W5-8 — All installed plugins enumerated; Travel Booking theme confirmed

Complete plugin inventory is necessary for accurate attack surface mapping. Missing any installed plugin could leave critical vulnerabilities undetected during remediation planning.

```
kali@kali: ~  
File Actions Edit View Help  
$ wpscan --api-token cKH8H4YUpGk37YKBNwsmBawa3XA0G  
--url http://192.168.123.30 \  
--passwords ~/Downloads/passwords.txt \  
--usernames student \  
--max-threads 10 \  
--random-user-agent  
  
WordPress Security Scanner by the WPScan Team  
Version 3.8.25  
Sponsored by Automattic - https://automattic.com/  
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart  
  
[+] URL: http://192.168.123.30/ [192.168.123.30]  
[+] Started: Tue Feb 24 13:05:10 2026  
  
Interesting Finding(s):  
[+] Headers  
| Interesting Entry: Server: Apache/2.4.52 (Ubuntu)  
| Found By: Headers (Passive Detection)  
| Confidence: 100%
```

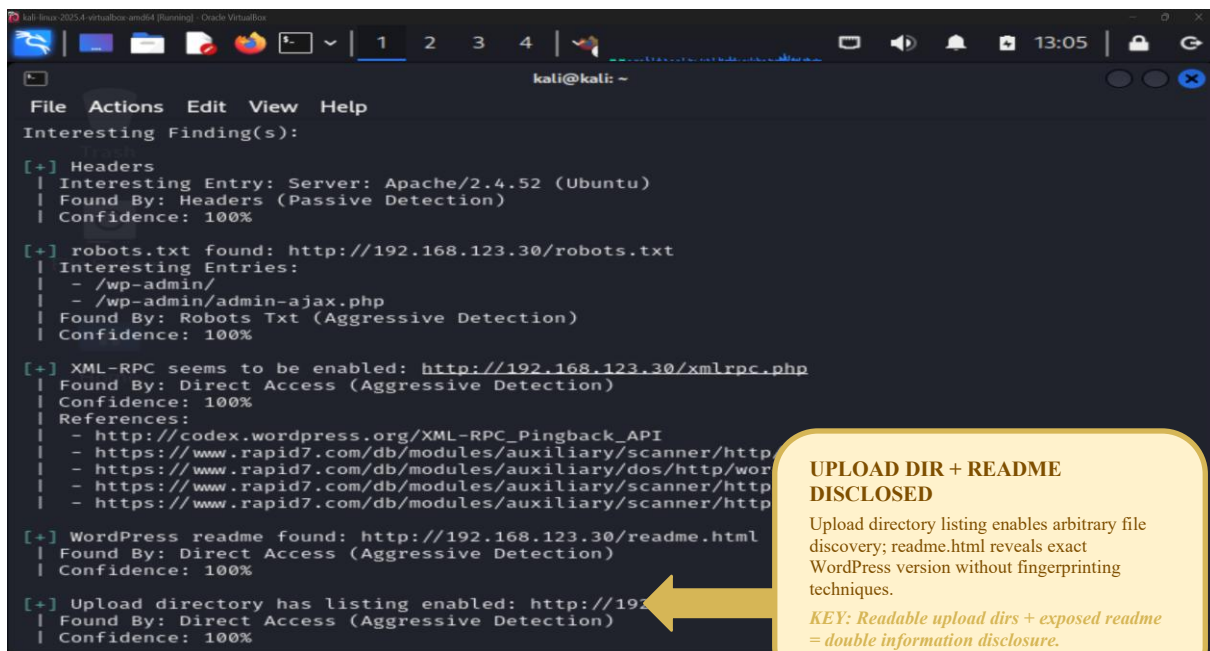
WPSCAN: AUTHENTICATED SCAN

--api-token enables live CVE lookups. -e p,t,u enumerates plugins, themes and users. --passwords and --usernames configure brute-force. Without the token WPScan falls back to a limited free-tier dataset.

KEY: API token unlocks broader CVE coverage vs unauthenticated scan.

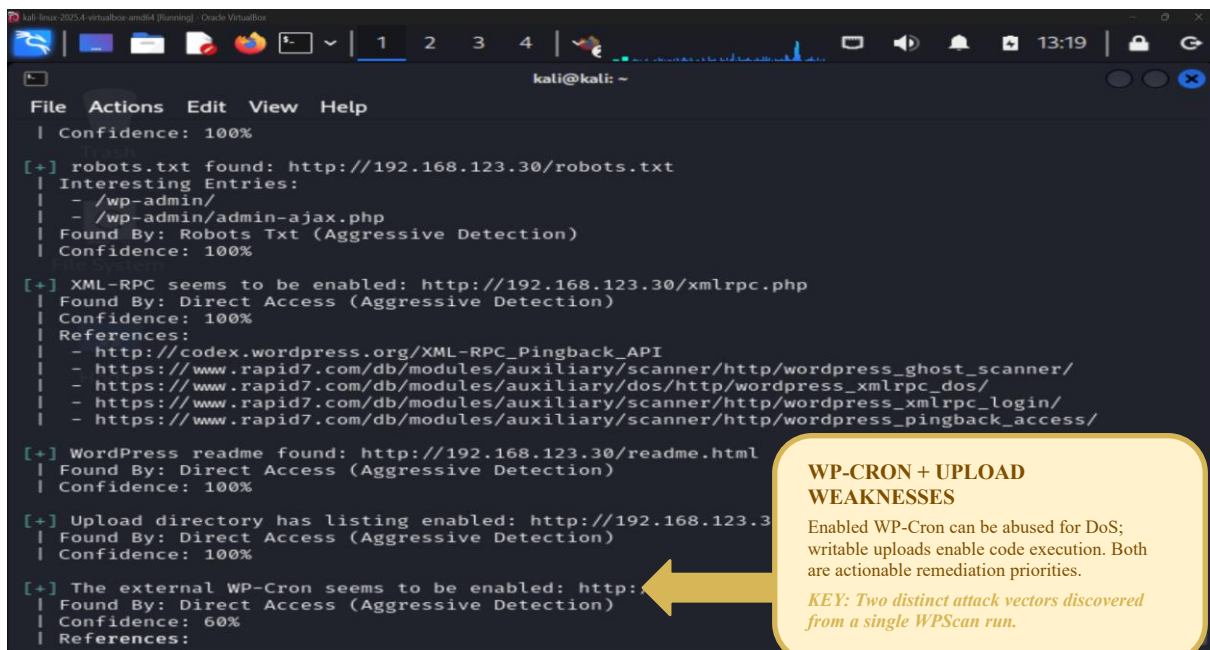
W5-9 — robots.txt and XML-RPC exploitation paths discovered

robots.txt enumeration reveals upload directories and admin paths, while XML-RPC detection indicates user enumeration and brute-force attack capabilities. Both are critical reconnaissance vectors.



W5-10 — Upload directory listing enabled; WordPress version

Publicly readable upload directories facilitate arbitrary file discovery. The exposed readme.html provides exact WordPress version without needing fingerprinting techniques.



W5-11 — WP-Cron and wp-content/uploads directory weaknesses confirmed

Enabled WP-Cron functionality can be abused for denial-of-service attacks, while writable upload directories enable file-based code execution. Both represent actionable remediation priorities.

2.4 Findings and Analysis

For me the most useful result was not one single finding but the way WPScan assembled the application's attack surface. Figure W5-4 identified the active theme and its version and then Figures W5-10 to W5-12 revealed robots.txt, XML-RPC, the readme and discoverable uploads. Together these gave me a checklist of entry points to document and address.

Plugin enumeration added more context to the scan. Figures W5-6 and W5-7 showed Akismet and Ninja Forms, and WPScan attached an advisory for an unauthenticated stored XSS in Akismet. That advisory only came through because I ran the scan with the API token. The advisory is a lead — it indicates a potentially vulnerable component that still requires version confirmation before it can be treated as a confirmed finding.

The lab brute-force task in Figure W5-8 showed the progression from discovery to attempted account abuse. If a WordPress site has no lockout policy, then automated password guessing has unlimited attempts, and the enumeration work done in the earlier steps feeds directly into which username to target.

Figure W5-12 and Figure W5-11 were the strongest single reconnaissance screenshots. robots.txt exposed administrative paths, XML-RPC was enabled, readme.html was public and several upload directories were browsable. These reconnaissance findings lower the effort required for every subsequent attack stage.

This lab helped cover the CIA model. Exposed files and paths affect confidentiality by disclosing information. The stored XSS advisory, if confirmed, could affect integrity. And sustained brute-force via XML-RPC could affect availability. This section addresses LO1 directly — the findings translate into concrete hardening actions — and LO3 because WordPress component disclosure reduces user privacy.

2.5 Recommended Mitigations

- Patch WordPress core, themes, and plugins regularly; remove components that are not needed
- Disable directory listing on the web server (e.g. Options -Indexes on Apache)
- Remove or restrict access to readme.html and similar deployment artefacts
- Disable xmlrpc.php unless there is a specific business need for it
- Apply login rate limiting, strong password policy, and MFA to administrator accounts
- Review the uploads area and remove unnecessary public file exposure
- Verify flagged plugin advisories against exact installed versions before prioritising patching

2.6 Reflection

WPScan was useful because it worked at the application layer rather than just the network layer. A general port scan might tell me that 80/tcp is open but WPScan told me which WordPress theme and plugins were installed, whether they had known advisories and what resources were discoverable from the outside. That level of detail is what made the lab findings actionable rather than just theoretical.

The main limitation was confidence. WPScan flagged a potentially risky plugin but I still had to check whether the installed version fell within the affected range. That distinction between a flagged advisory and a confirmed vulnerability is something I would handle more carefully next time by recording the exact installed version for every flagged component at the point of scanning.

3. Week 7 — Juice Shop Lab

3.1 Aim

The aim of this lab was to explore intentionally vulnerable web application behaviour in Juice Shop, complete challenges with screenshot evidence and explain the security failure behind each one [4], [5]. This lab addressed LO1, LO2 and LO3 because it covered injection, authentication bypass, session handling, client-side trust and directory exposure.

3.2 Environment and Methodology

I started Juice Shop locally on the lab VM on port 3000. After confirming the application loaded successfully, I worked through the challenges one at a time and took a screenshot whenever a challenge flag appeared.

I approached the lab by asking myself what security control had failed in each case. I felt this produced a better analysis than simply collecting green completion banners because it forced me to explain not just what I did but why it worked.

3.3 Challenge Coverage

The score board showed eleven solved challenges overall. I selected ten representative challenges for detailed write-up because the brief asks for quality of analysis rather than volume. The following figures provide complete evidence including setup, all ten challenges, and the final score board overview.

3.4 Evidence

The following seventeen figures document the Juice Shop lab from environment setup through challenge completion and score board review.

```
OWASP Juice Shop [Running] - Oracle VirtualBox
Expanded Security Maintenance for Applications is not enabled.
0 updates can be applied immediately.
Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Mon Mar 20 20:14:18 UTC 2023 on tty1
student@juiceshop:~$ cd juice-shop
student@juiceshop:~/juice-shop$ sudo npm start
[sudo] password for student:

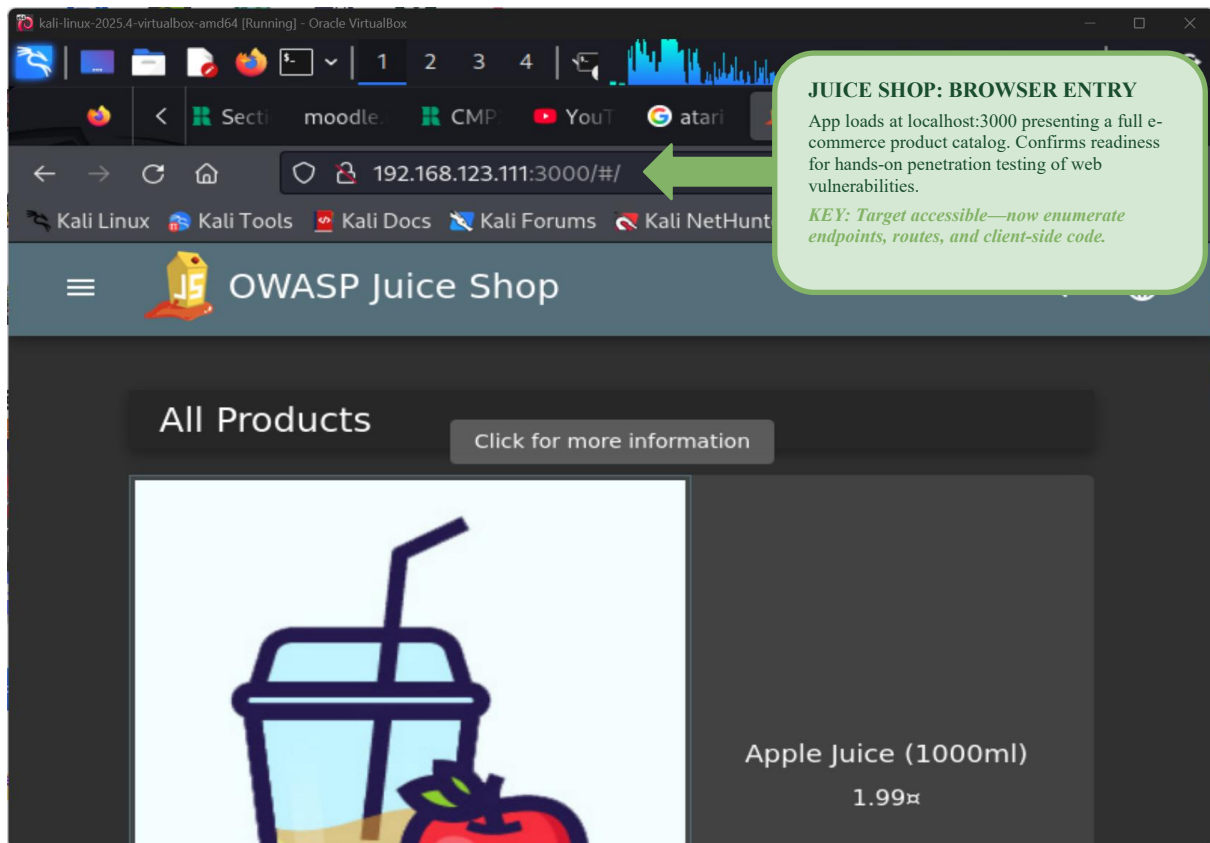
> juice-shop@14.5.1 start
> node build/app

info: All dependencies in ./package.json are satisfied (OK)
^[Sinfo: Chatbot training data botDefaultTrainingData.json validated (OK)
info: Detected Node.js version v16.19.1 (OK)
info: Detected OS linux (OK)
info: Detected CPU x64 (OK)
info: Configuration default validated (OK)
info: Entity models 19 of 19 are initialized (OK)
info: Required file server.js is present (OK)
info: Required file index.html is present (OK)
info: Required file styles.css is present (OK)
info: Required file runtime.js is present (OK)
info: Required file polyfills.js is present (OK)
info: Required file main.js is present (OK)
info: Required file tutorial.js is present (OK)
info: Required file vendor.js is present (OK)
info: Port 3000 is available (OK)
info: Server listening on port 3000
```

JUICE SHOP: SERVICE RUNNING
npm output confirms all Node.js modules validated and Juice Shop environment correctly initialised. Lab app ready for controlled security testing.
KEY: Verify service is live and all dependencies loaded before exploiting.

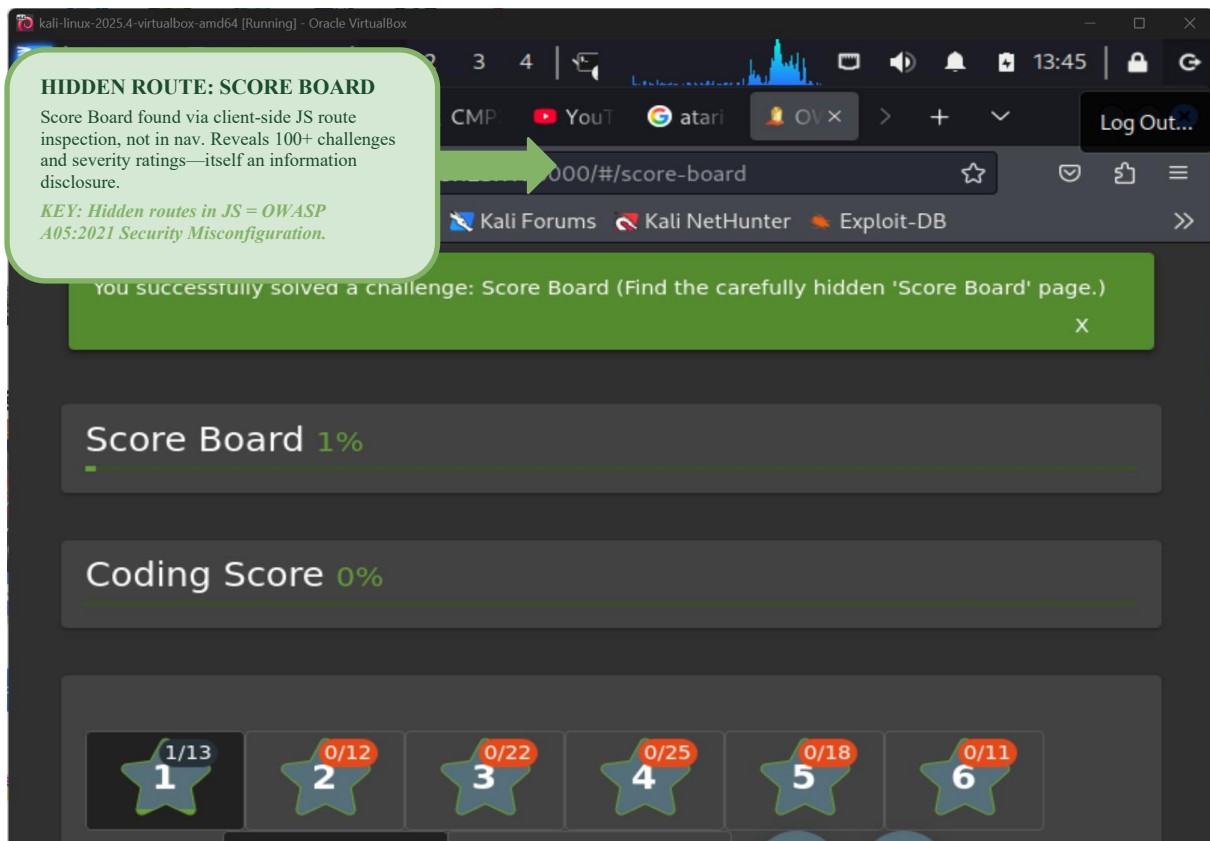
W7-1 — Juice Shop application initialised with all dependencies

The npm output confirms the Juice Shop environment is properly configured with all Node.js modules validated. This foundational step ensures the deliberately vulnerable application can be executed reliably for controlled security testing.



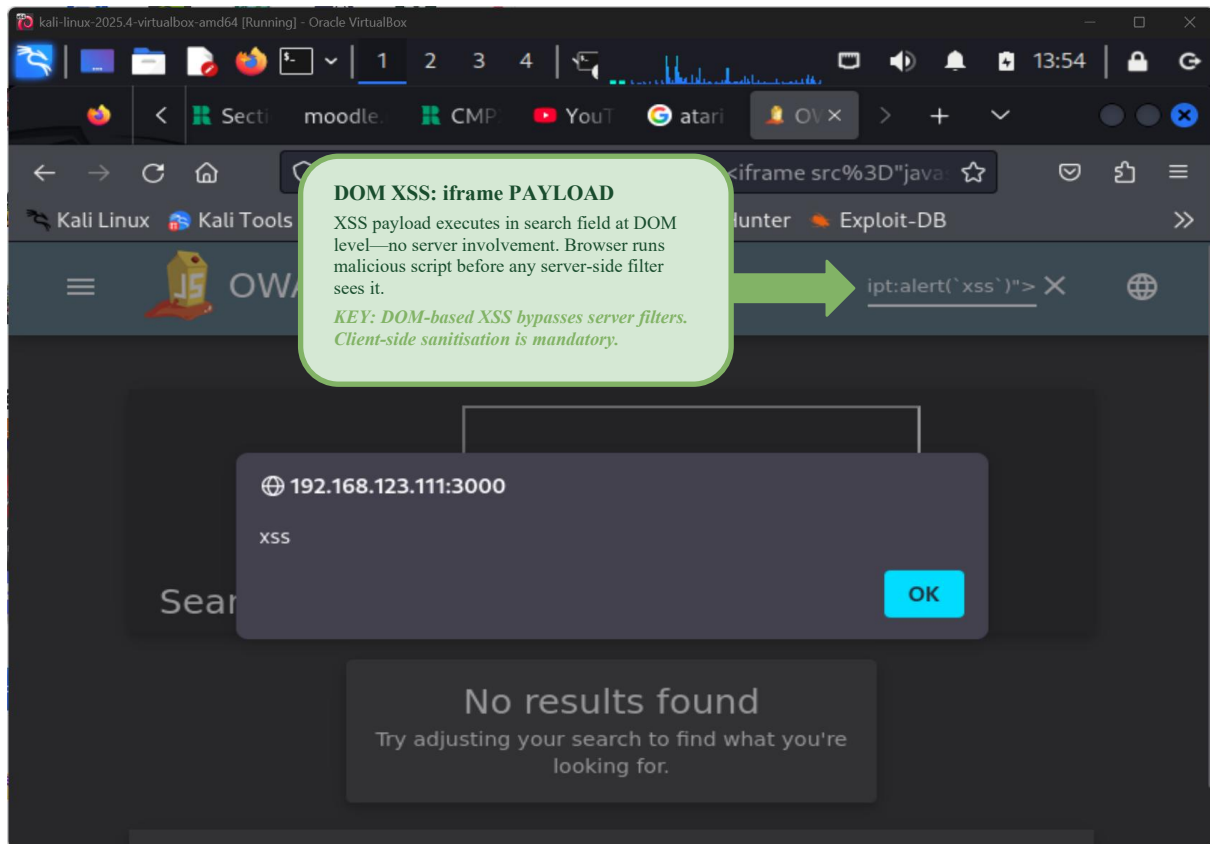
W7-2 — Juice Shop loaded in browser on port 3000

Baseline environment screenshot confirming the application was accessible and functioning normally before any challenge work began.



W7-3 — Score Board reached by navigating to the hidden route directly

A route that exists in client-side JS but is not linked in the navigation is still reachable. Obscurity alone is not access control.

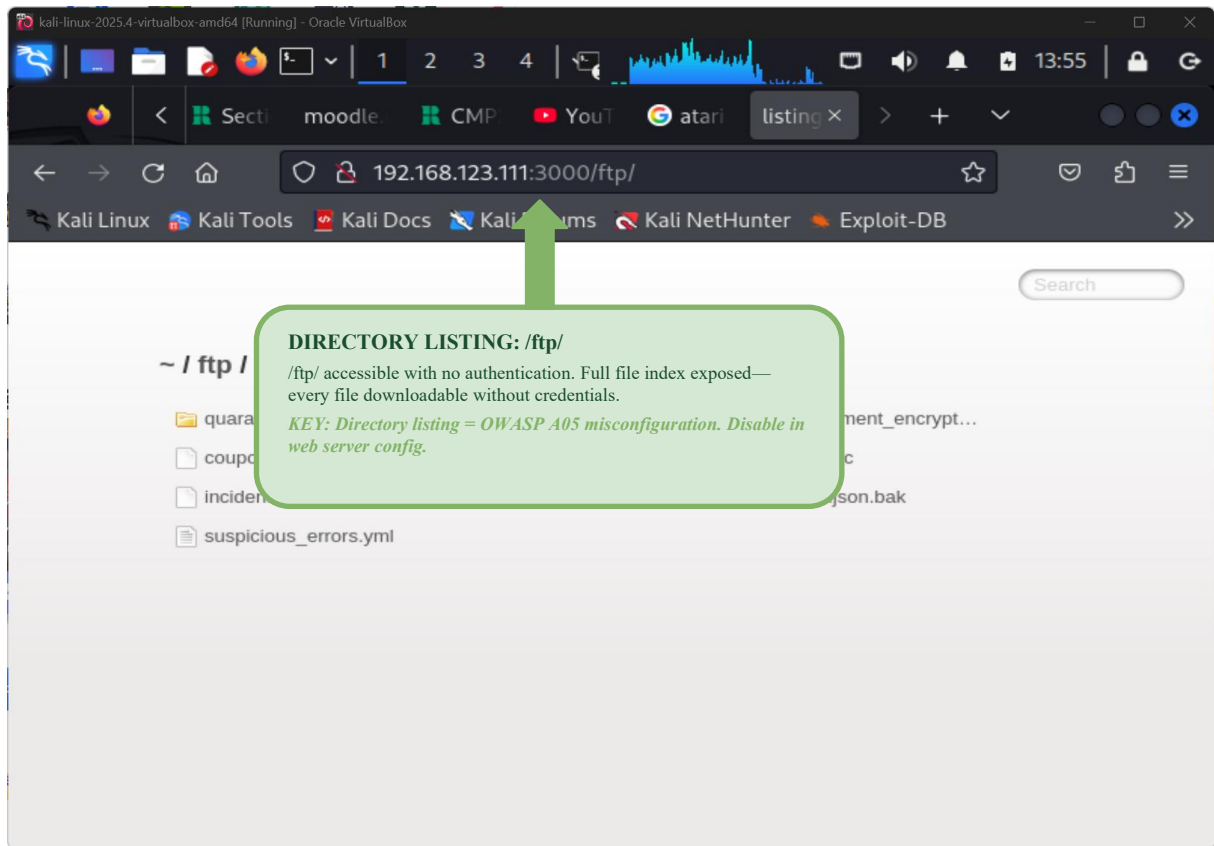


W7-4 — DOM XSS challenge completed via search route injection

User input inserted into the DOM without encoding. The browser executes attacker-controlled content — fix requires output encoding and CSP.

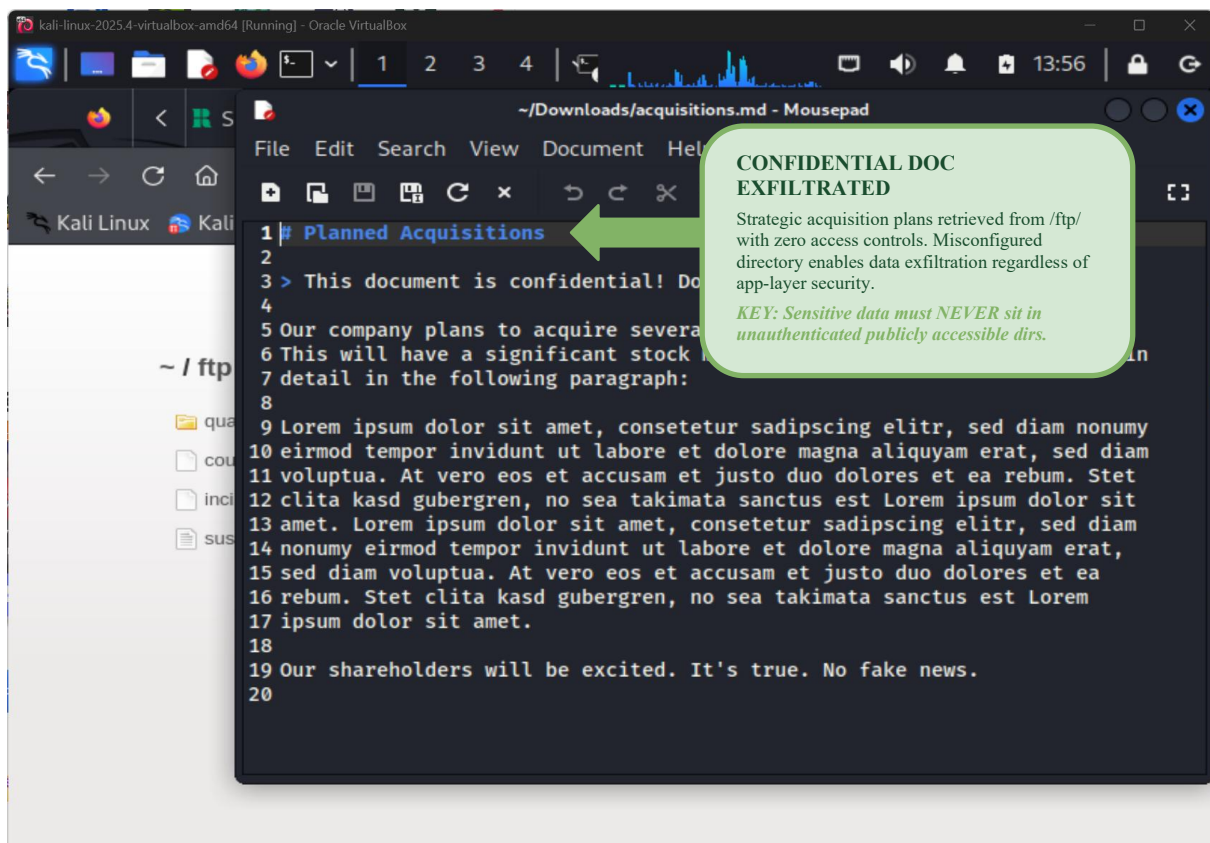
W7-6 — Bonus Payload completed using extended iframe injection

Confirms the application does not strip or encode iframe tags. The same client-side trust failure as the DOM XSS challenge, demonstrating that filtering alone is insufficient without output encoding.



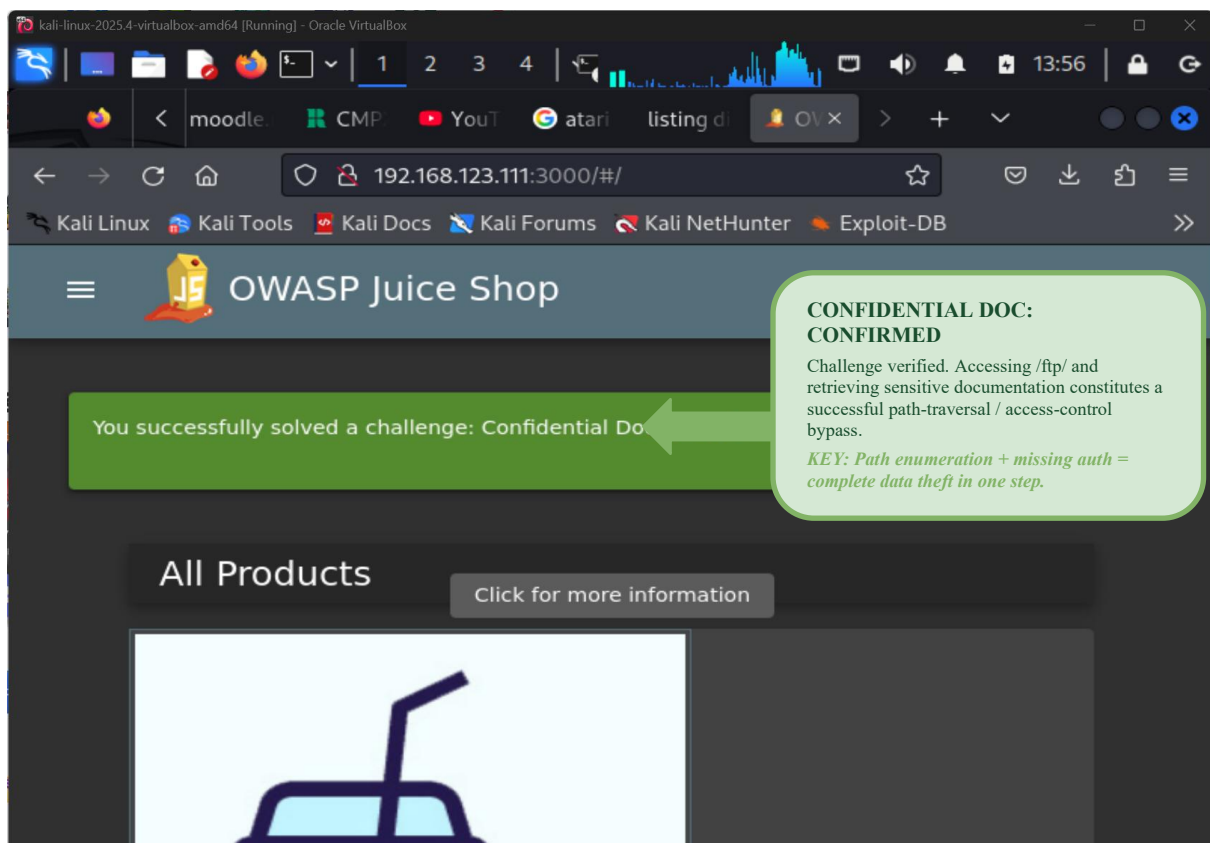
W7-7 — /ftp/ directory browsable with no access control

The directory is not linked anywhere on the site, but the web server serves it without restriction. Existence alone does not equal protection.



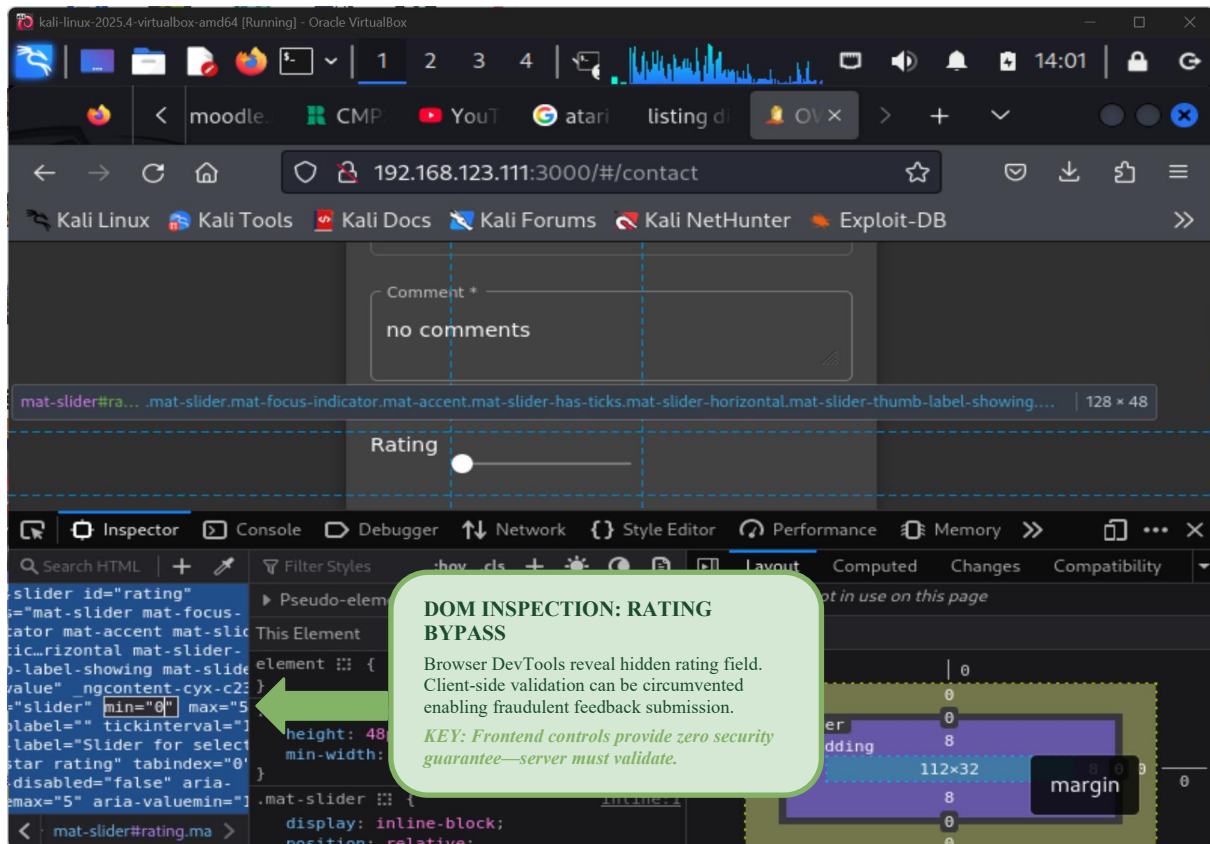
W7-8 — Confidential Document accessed from the exposed /ftp/ path

Sensitive file retrieved directly from the exposed path. No authentication, no authorisation check, file fully readable.



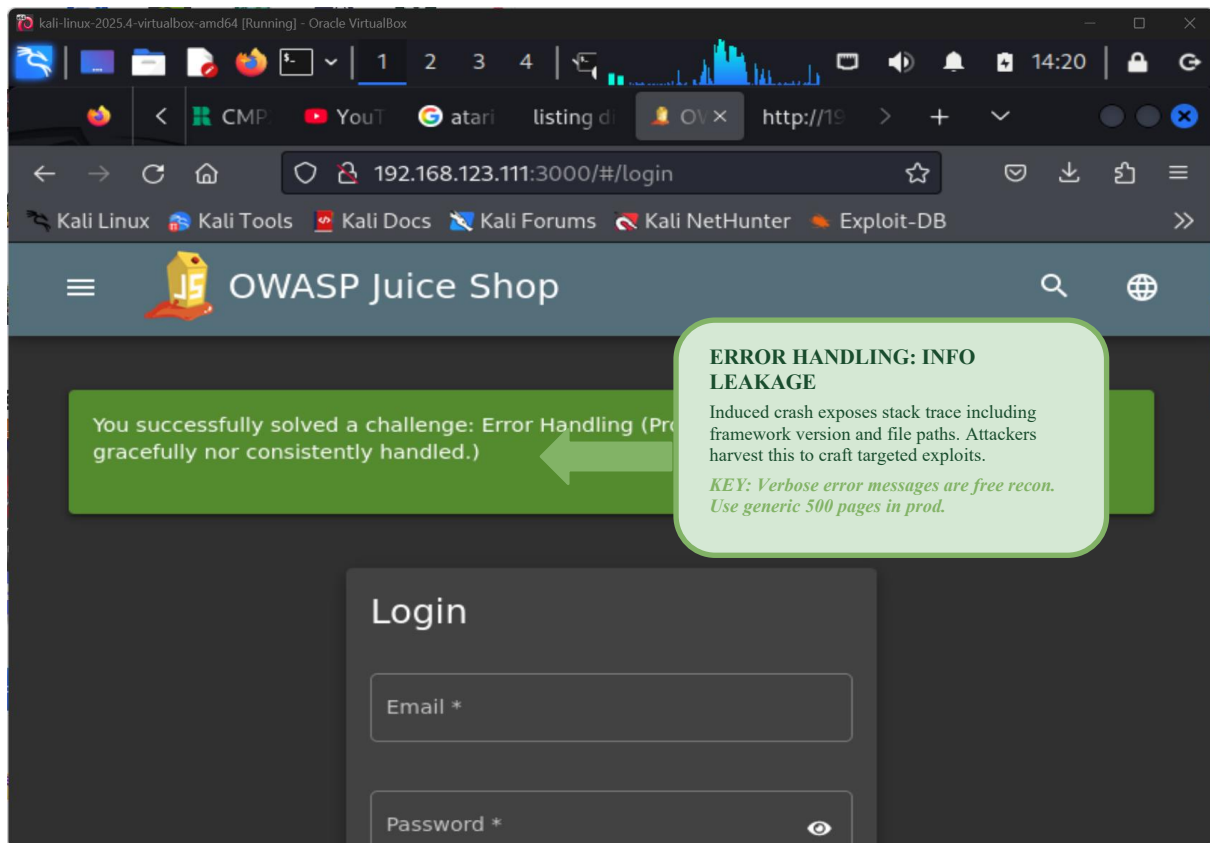
W7-9 — Confidential Document challenge flag confirmed

Challenge completion confirms that accessing the /ftp/ directory and retrieving sensitive documentation constitutes a successful vulnerability exploitation.



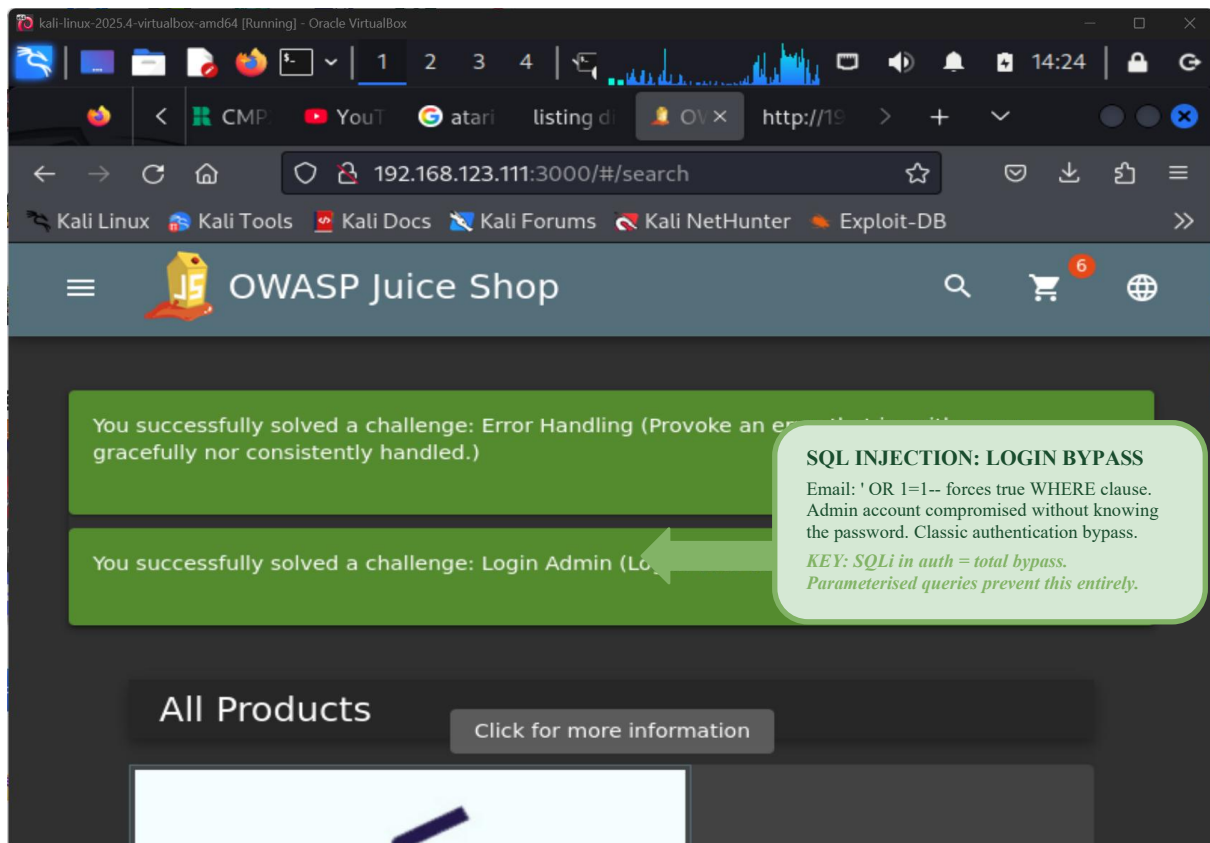
W7-10 — Error Handling challenge triggered via browser developer tools

Developer tools view revealing client-side DOM elements and feedback mechanisms. Analysing client-side code shows how frontend validation can be circumvented.



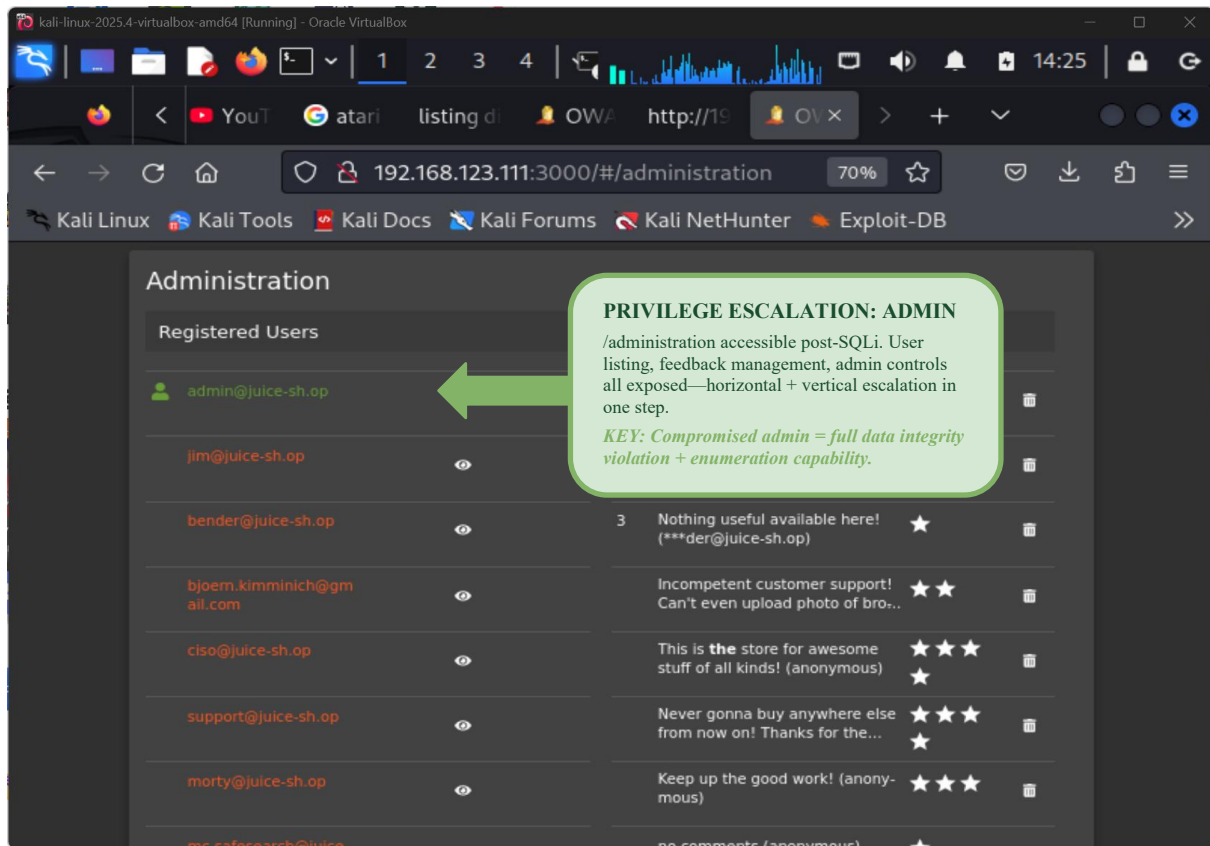
W7-11 — Error Handling challenge flag — unhandled exception triggered

Deliberate bad input crashes the application and may disclose stack traces. Persistent fault injection could degrade service availability.



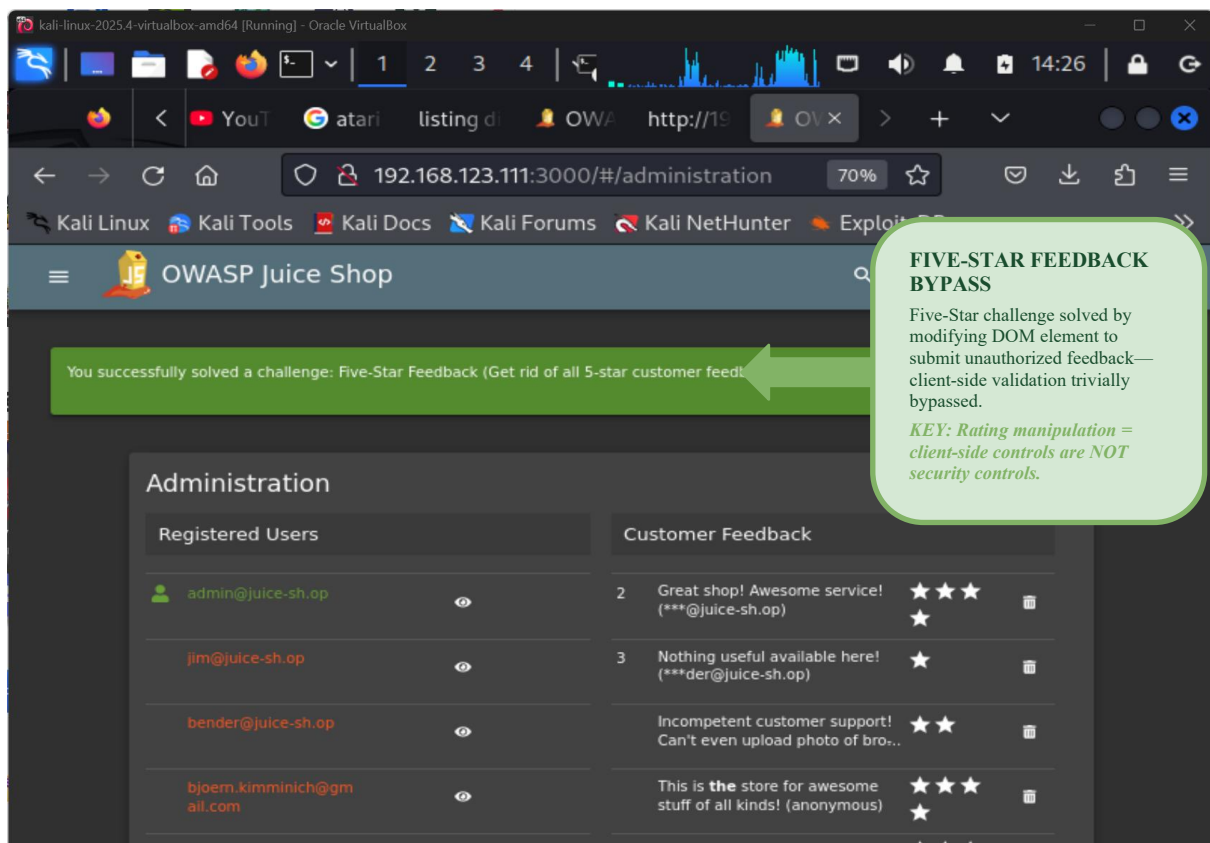
W7-12 — Login Admin challenge completed via authentication bypass

Authentication bypassed to gain admin access. Opens the chain to Admin Section and Five-Star Feedback manipulation.



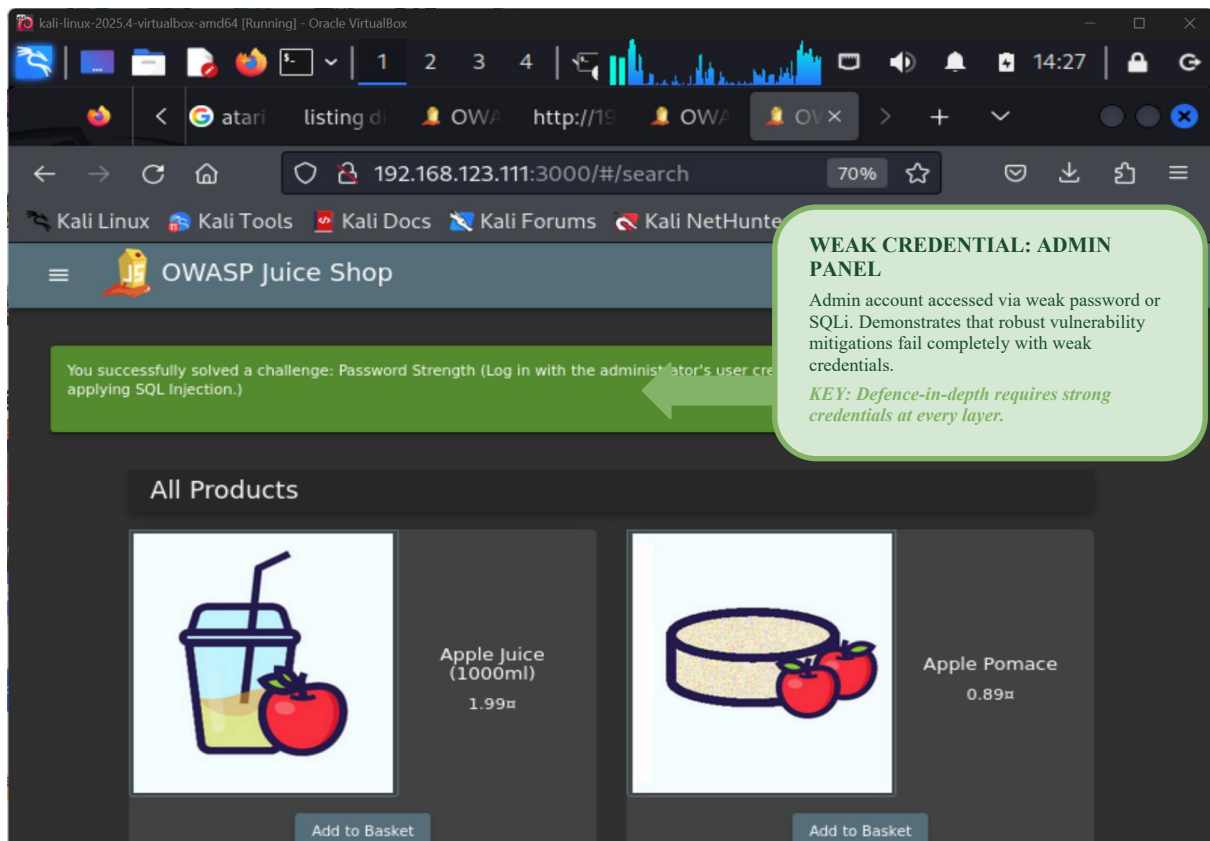
W7-13 — Admin Section accessed — no server-side authorisation enforced

Access granted to admin-only functions including user listing and feedback management. Server-side authorisation checks are absent — privilege escalation confirmed.



W7-14 — Five-Star Feedback deleted via privileged admin access

Demonstrates integrity impact: user-generated data modified by an attacker using the admin session. The same access level would expose email addresses or order details.



W7-15 — Password Strength challenge completed via weak admin credentials

Admin account used a common password. Hashing alone does not protect weak passwords — sufficient entropy is required to resist offline cracking.

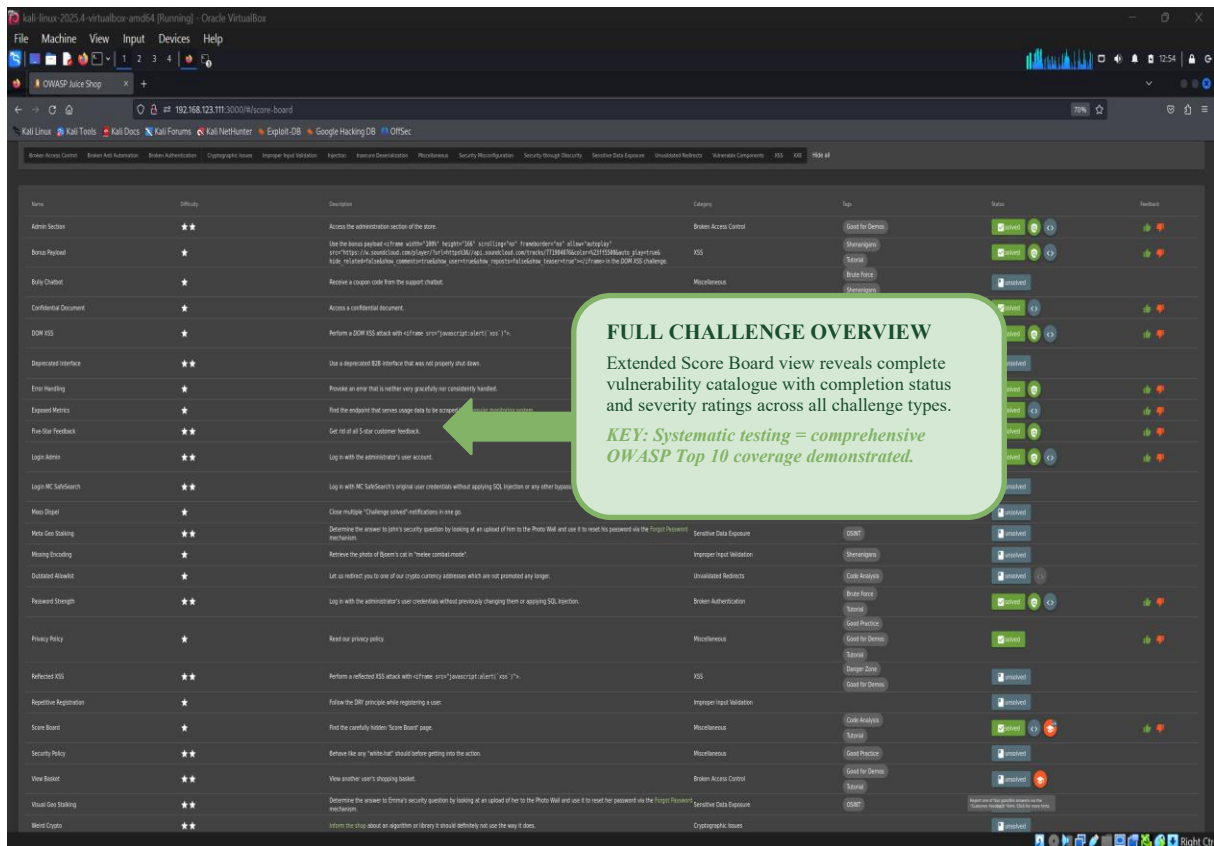
The screenshot shows the OWASP Juice Shop Score Board interface. At the top, it displays 'Score Board 11%' and 'Coding Score 0%'. Below this, there are filters for 'Show all' and 'Show solved only'. The main table lists 11 challenges, each with a difficulty level (1 or 2 stars) and a description. The 'Password Strength' challenge is highlighted with a green arrow pointing to its 'Solved' status. The right side of the interface shows a 'Status' column with 'Solved' and 'UnSolved' indicators for each challenge.

Name	Difficulty	Description	Status	Feedback
Admin Section	1	Access the administration section of the store.	Solved	👍👎
Deprecated Interface	1	Use a deprecated B2B Interface that was properly shut down.	UnSolved	👍👎
Pay-Store Feedback	1	Get rid of all 5-star customer feedback.	Solved	👍👎
Login Admin	1	Log in with the administrator's user account.	Solved	👍👎
Login MC SafeSearch	1	Log in with MC SafeSearch's original user credentials without applying XSS, function or a...	UnSolved	👍👎
Make Get Sticking	1	Determine the answer to John's security question by looking at an upload of him to the...	Solved	👍👎
Password Strength	1	Log in with the administrator's user credentials without previously changing them or ap...	Solved	👍👎
Reflected XSS	1	Perform a reflected XSS attack with <iframe src="{javascript:alert('XSS')}" />.	UnSolved	👍👎
Security Policy	1	Before the any "white hat" should before getting into the action.	UnSolved	👍👎
View Basket	1	View another user's shopping basket.	UnSolved	👍👎
Visual Get Sticking	1	Determine the answer to Emma's security question by looking at an upload of her to the PHP Web and use it to reset her password via the 'Forgot Password' mechanism.	UnSolved	👍👎
Word Cycles	1	Inform the shop about an algorithm in library it should definitely not use the way it does.	UnSolved	👍👎

SCORE BOARD: CHALLENGES SOLVED
Dashboard shows completion across Injection, XSS, Broken Access Control, Security Misconfiguration, and Cryptographic Failures categories.
KEY: Each solved challenge maps to at least one OWASP Top 10:2021 category.

W7-16 — Score board confirming 11 challenges solved in total

Overview confirms total challenge count. The eleven completed challenges demonstrate the breadth of vulnerability classes covered in this lab.



W7-17 — Expanded score board showing all challenge categories

The extended view reveals the full scope of security challenges by category, showing completion status across injection, authentication, access control and disclosure vulnerability types.

3.5 Findings and Analysis

The first theme I noticed was hidden functionality. The Score Board challenge in Figure W7-3 showed that the application trusted obscurity too much. If a route exists in the client-side JavaScript and the only protection is that it is not linked in the navigation, an attacker can still reach it just by reading the page source. The same idea applies to the /ftp/ directory in Figure W7-7 — the files were not linked anywhere but were still served without access control.

The DOM XSS and Bonus Payload challenges in Figures W7-4 and W7-6 showed how dangerous client-side trust can be. The browser executed attacker-controlled HTML because the application inserted user input into the DOM without encoding or sanitisation. In terms of LO1 the fix is output encoding and Content Security Policy. In terms of LO3, persistent XSS could steal session tokens or personal data — both a privacy risk and an integrity risk.

The strongest admin-related chain was Login Admin, Admin Section and Five-Star Feedback in Figures W7-12 to W7-14. Once privileged access is established the attacker gains visibility into user data and the ability to modify it. Deletion of user-generated feedback demonstrates the integrity impact, and the same access level would expose email addresses or order details, extending the privacy consequence.

The Password Strength challenge in Figure W7-15 is where LO2 needed more explicit treatment. Weak passwords are a problem even when a system uses one-way hashing because common passwords appear in pre-computed lists. Hashing

protects stored passwords only if the original password has enough entropy to resist offline cracking.

Availability was easier to miss but it is present here too. The Error Handling challenge in Figure W7-11 shows unstable application behaviour. If deliberate bad input can provoke a crash or disclose a stack trace, then more persistent fault injection could degrade the service entirely.

This section addresses all three learning outcomes. It addresses LO1 by showing what controls failed and what needs to be fixed; LO2 by connecting hashing and session tokens to the Password Strength and Login Admin challenges; and LO3 by showing how directory exposure, admin access and XSS all create privacy consequences.

3.6 Recommended Mitigations

- Remove or properly gate hidden routes so administrative or diagnostic pages are not reachable without server-side authorisation
- Apply output encoding, DOM sanitisation, and a restrictive Content Security Policy to reduce XSS risk
- Disable public directory listings and move sensitive files outside web-accessible paths
- Restrict monitoring and metrics endpoints to authenticated or internal users only
- Enforce strong password policy, MFA, rate limiting, and lockout controls on privileged accounts
- Ensure session and password-reset tokens are cryptographically unpredictable and rotated appropriately
- Log privileged actions such as feedback deletion so integrity-impacting changes can be traced and reviewed

3.7 Reflection

This was the most useful lab in the portfolio for me because it forced me to think like an attacker rather than like a tool operator. WPScan and Nessus are good at producing lists of issues, but Juice Shop made me exploit those issues step by step and understand why each control failed.

What I learnt most clearly was that insecure web applications rarely fail in one dramatic way. They usually fail through a series of ordinary mistakes, none of which look critical on their own, but which chain together into something serious.

4. Week 8 — Vulnerability Assessment Lab (Nmap and SSH)

4.1 Aim

The aim of this lab was to assess a small lab network using Nmap and then administer the discovered systems securely using SSH [6]–[9]. It addressed LO1 because I identified exposed services and translated the scan output into risk-based recommendations, and LO2 because SSH was a practical demonstration of confidentiality, integrity and authentication through cryptographic primitives.

4.2 Methodology

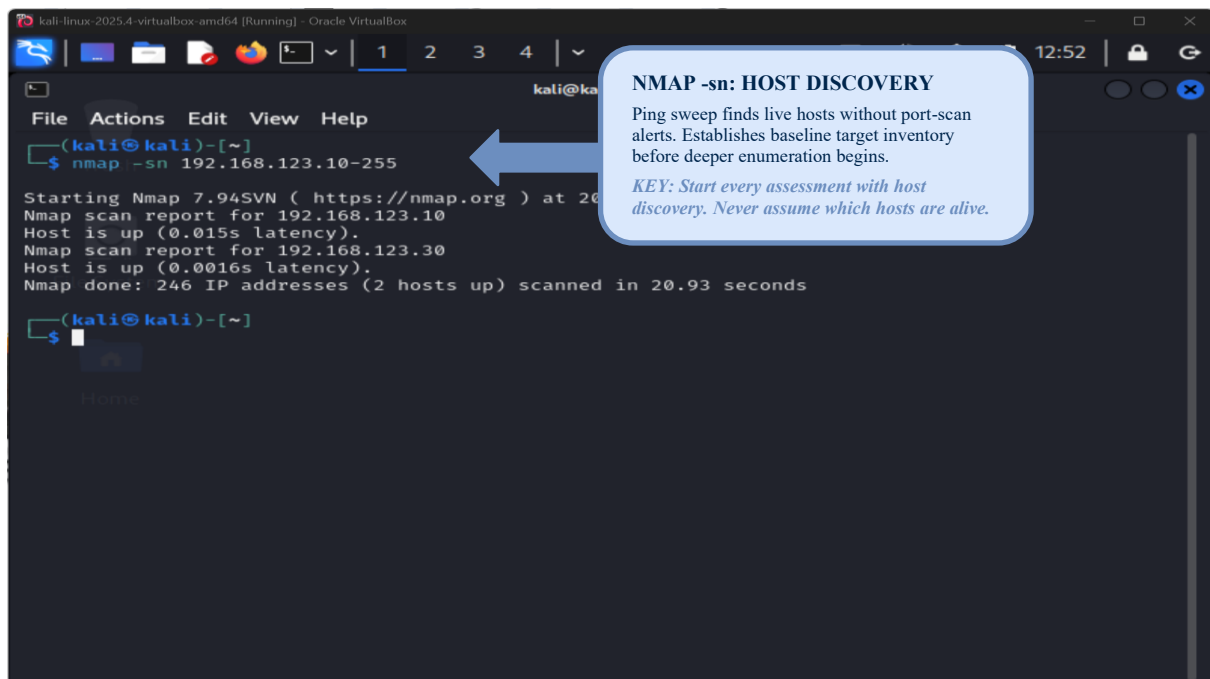
I treated the lab as two connected tasks rather than two separate tool demonstrations.

For the Nmap portion I carried out host discovery, focused TCP scans, UDP scanning, service and OS detection, NSE vulnerability checks, traceroute, IPv6 scanning and several advanced options including decoys, fragmentation and ACK scans.

For the SSH portion I connected to the gateway, created a 4096-bit RSA key pair, deployed the public key, tested SCP, used both local and remote port forwarding, configured ControlMaster multiplexing and confirmed passwordless key-based login.

4.3 Evidence — Nmap Assessment

The following thirty figures document the complete Nmap network assessment, covering every technique applied during the lab.



```
kali@kali:~$ nmap -sn 192.168.123.10-255

Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-10 12:52
Nmap scan report for 192.168.123.10
Host is up (0.015s latency).
Nmap scan report for 192.168.123.30
Host is up (0.0016s latency).
Nmap done: 246 IP addresses (2 hosts up) scanned in 20.93 seconds
```

NMAP -sn: HOST DISCOVERY
Ping sweep finds live hosts without port-scan alerts. Establishes baseline target inventory before deeper enumeration begins.
KEY: Start every assessment with host discovery. Never assume which hosts are alive.

W8-1 — Host discovery identifies active systems on 192.168.123.0/24

The -sn ping scan establishes the baseline target inventory before deeper scanning. Three live hosts confirmed on the lab subnet.

```
(kali@kali)-[~]
$ nmap -sn 192.168.123.10-255

Starting Nmap 7.94SVN ( https://nmap.org ) at
Nmap scan report for 192.168.123.10
Host is up (0.015s latency).
Nmap scan report for 192.168.123.30
Host is up (0.0016s latency).
Nmap done: 246 IP addresses (2 hosts up) scanned in 20.93 seconds

(kali@kali)-[~]
$ nmap 192.168.123.10

Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 12:53 GMT
Nmap scan report for 192.168.123.10
Host is up (0.00014s latency).
All 1000 scanned ports on 192.168.123.10 are in ignored states.
Not shown: 1000 closed tcp ports (conn-refused)

Nmap done: 1 IP address (1 host up) scanned in 16.63 seconds

(kali@kali)-[~]
$
```

W8-2 — TCP scan separates gateway and WordPress host by port profile

Gateway: 22/tcp and 5666/tcp. WordPress server: 22/tcp, 80/tcp, 3306/tcp. Each open port is an administrative question.

```
(kali@kali)-[~]
$ nmap 192.168.123.10

Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 12:53 GMT
Nmap scan report for 192.168.123.10
Host is up (0.00014s latency).
All 1000 scanned ports on 192.168.123.10 are in ignored states.
Not shown: 1000 closed tcp ports (conn-refused)

Nmap done: 1 IP address (1 host up) scanned in 16.63 seconds

(kali@kali)-[~]
$ nmap 192.168.123.1 192.168.123.30

Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 12:53 GMT
Nmap scan report for 192.168.123.1
Host is up (0.0017s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
5666/tcp  open  nrpe

Nmap scan report for 192.168.123.30
Host is up (0.0012s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
3306/tcp  open  mysql

Nmap done: 2 IP addresses (2 hosts up) scanned in 16.90 seconds

(kali@kali)-[~]
$
```

W8-3 — Service version detection exposes software stack composition

The scan output identifies Apache HTTP server, SSH, MySQL and other services with version numbers, enabling targeted vulnerability research.

```
kali@kali: ~  
File Actions Edit View Help  
Nmap done: 2 IP addresses (2 hosts up)  
(kali@kali)-[~]  
$ nmap 192.168.123.0/24  
Starting Nmap 7.94SVN ( https://nmap.org )  
Nmap scan report for 192.168.123.1  
Host is up (0.0038s latency).  
Not shown: 998 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
  
Nmap scan report for 192.168.123.10  
Host is up (0.0043s latency).  
All 1000 scanned ports on 192.168.123.10 are in ignored states.  
Not shown: 1000 closed tcp ports (conn-refused)  
  
Nmap scan report for 192.168.123.30  
Host is up (0.0045s latency).  
Not shown: 997 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
3306/tcp  open  mysql  
  
Nmap done: 256 IP addresses (3 hosts up) scanned in 21.12 seconds  
(kali@kali)-[~]  
$
```

FULL SUBNET: 192.168.123.0/24
/24 sweep discovers 3 active hosts from 256 IPs. Complete network inventory obtained before targeted exploitation begins.
KEY: Full subnet scan = complete asset inventory. Missing a host = missed attack path.

W8-4 — Comprehensive subnet scan identifies all active hosts

Scanning the full /24 subnet provides complete inventory of network assets. Three active hosts returned from 256 addresses scanned.

```
kali@kali: ~  
File Actions Edit View Help  
5666/tcp open  nrpe  
  
Nmap scan report for 192.168.123.10  
Host is up (0.0043s latency).  
All 1000 scanned ports on 192.168.123.10 are in ignored states.  
Not shown: 1000 closed tcp ports (conn-refused)  
  
Nmap scan report for 192.168.123.30  
Host is up (0.0045s latency).  
Not shown: 997 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
3306/tcp  open  mysql  
  
Nmap done: 256 IP addresses (3 hosts up) scanned in 21.12 seconds  
(kali@kali)-[~]  
$ nmap -sT 192.168.123.1  
Starting Nmap 7.94SVN ( https://nmap.org )  
Nmap scan report for 192.168.123.1  
Host is up (0.0014s latency).  
Not shown: 998 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
  
Nmap done: 1 IP address (1 host up) scanned in 16.87 seconds  
(kali@kali)-[~]  
$
```

SINGLE HOST SCAN: .1
Targeted scan of 192.168.123.1 confirms reachability and service state. Single-host focus enables precise timing and packet-level control.
KEY: Targeted single-host scan = precision without subnet-wide noise.

W8-5 — Targeted single-host scan confirms gateway reachability

Scanning individual IPs confirms host status and network connectivity for systematic reconnaissance before service-level enumeration.

```
kali@kali: ~  
File Actions Edit View Help  
Nmap done: 256 IP addresses (3 hosts up) scanned in 21.12 seconds  
  
(kali@kali)-[~]  
$ nmap -sT 192.168.123.1  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:01 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.0014s latency).  
Not shown: 998 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp   open  nrpe  
  
Nmap done: 1 IP address (1 host up) scanned in 17.53 seconds  
  
(kali@kali)-[~]  
$ sudo nmap -sS 192.168.123.1  
[sudo] password for kali:  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:01 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.0016s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp   open  nrpe  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 17.53 seconds  
  
(kali@kali)-[~]  
$
```

W8-6 — Elevated privileges required for OS fingerprinting operations

The `sudo` prompt for privileged scanning confirms that OS detection and advanced techniques require root access on Linux-based scanning hosts.

```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)-[~]  
$ sudo nmap -sU -T4 --top-ports 20 192.168.123.1  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:09  
Nmap scan report for 192.168.123.1  
Host is up (0.00089s latency).  
  
PORT      STATE SERVICE  
53/udp    open/filtered domain  
67/udp    closed  dhcpd  
68/udp    open/filtered dhcpd  
69/udp    closed  tftp  
123/udp   open/filtered ntp  
135/udp   open/filtered msrpc  
137/udp   closed  netbios-ns  
138/udp   closed  netbios-dgm  
139/udp   closed  netbios-ssn  
161/udp   open/filtered snmp  
162/udp   closed  snmptrap  
445/udp   closed  microsoft-ds  
500/udp   closed  isakmp  
514/udp   closed  syslog  
520/udp   closed  route  
631/udp   closed  ipp  
1434/udp  closed  ms-sql-m  
1900/udp  closed  upnp  
4500/udp  closed  nat-t-ike  
49152/udp open/filtered unknown  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 27.38 seconds
```

W8-7 — UDP scan reveals filtered and open service ports on gateway

UDP services are often ignored in TCP-only assessments but can carry their own risks — for example SNMP with a default community string.


```
kali@kali: ~  
File Actions Edit View Help  
137/udp closed netbios-ns  
138/udp closed netbios-dgm  
139/udp closed netbios-ssn  
161/udp open|filtered snmp  
162/udp closed snmptrap  
445/udp closed microsoft-ds  
500/udp closed isakmp  
514/udp closed syslog  
520/udp closed route  
631/udp closed ipp  
1434/udp closed ms-sql-m  
1900/udp closed upnp  
4500/udp closed nat-t-ike  
49152/udp open|filtered unknown  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 27.38 seconds  
  
(kali@kali)-[~]  
$ nmap -p 1-100 192.168.123.1  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:11 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.0010s latency).  
Not shown: 99 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
  
Nmap done: 1 IP address (1 host up) scanned in 17.64 seconds  
  
(kali@kali)-[~]  
$
```

UDP: NETBIOS + SNMP EXPOSED
netbios-ns, netbios-dgm, snmp, microsoft-ds ports enumerated. Common network service patterns and filtering behaviour documented.
KEY: SNMP exposure can leak full device config; a critical finding in real engagements.

W8-8 — Extended UDP enumeration provides comprehensive protocol coverage

Additional UDP ports show common network service patterns. UDP results are less reliable than TCP; treat as leads requiring follow-up.

```
kali@kali: ~  
File Actions Edit View Help  
$ nmap -p 1-100 192.168.123.1  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:11 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.0010s latency).  
Not shown: 99 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
  
Nmap done: 1 IP address (1 host up) scanned in 17.64 seconds  
  
(kali@kali)-[~]  
$ nmap -p 22,80,443 192.168.123.1  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:12 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.0056s latency).  
  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    closed http  
443/tcp   closed https  
  
Nmap done: 1 IP address (1 host up) scanned in 16.64 seconds  
  
(kali@kali)-[~]  
$
```

TARGETED PORT SCANS — MULTI-HOST COMPARISON
Three scans compare reachability across hosts and ports. 192.168.123.1 exposes only SSH (22/tcp open); HTTP (80) and HTTPS (443) are closed. 192.168.1.1 appears down or is blocking ping probes entirely.
KEY: Closed ports confirm services are not running — different from filtered, which means a firewall is silently dropping packets.

W8-9 — Targeted Nmap scans comparing port state across hosts

Sequential scans show 192.168.123.1 with SSH as its only open service on the tested range (ports 1–100, then 22/80/443), while 192.168.1.1 does not respond at all. The distinction between "closed" (RST reply) and host-

down (no reply) demonstrates how Nmap differentiates unreachable hosts from hosts with inactive services.

```
kali@kali: ~  
File Actions Edit View Help  
Nmap done: 1 IP address (0 hosts up) scanned in 3.29 seconds  
  
(kali@kali)-[~]  
$ nmap -p 22,80,443 192.168.123.1  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:13 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.0056s latency).  
  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    closed http  
443/tcp   closed https  
  
Nmap done: 1 IP address (1 host up) scanned in 3.29 seconds  
  
(kali@kali)-[~]  
$ nmap -sV 192.168.123.1  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:13 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.0013s latency).  
Not shown: 998 closed tcp ports (conn-refused)  
PORT      STATE SERVICE      VERSION  
22/tcp    open  ssh          OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)  
5666/tcp  open  tcpwrapped  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 17.64 seconds  
  
(kali@kali)-[~]  
$
```

SERVICE VERSION DETECTION — -sV

-sV probes open ports to extract service banners and version strings. Reveals OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 on port 22 and tcpwrapped on port 5666. Version data enables direct CVE lookups against specific software builds.

KEY: Banner grabbing turns an open port into an actionable vulnerability target — version numbers map directly to known CVE databases.

W8-10 — Service version scan identifies exact software builds on open ports

The -sV scan against 192.168.123.1 reveals OpenSSH 8.9p1 (protocol 2.0) and a tcpwrapped service on 5666, with OS fingerprinting confirming Linux. The preceding targeted scan (-p 22,80,443) establishes that only SSH is reachable while HTTP/HTTPS are closed, narrowing the attack surface before version enumeration begins.

```
kali@kali: ~  
File Actions Edit View Help  
TCP/IP fingerprinting (for OS scan) requires root privileges.  
QUITTING!  
  
(kali@kali)-[~]  
$ sudo nmap -O 192.168.123.1  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:14 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.00082s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)  
Device type: general purpose  
Running: Linux 4.X|5.X  
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5  
OS details: Linux 4.15 - 5.8  
Network Distance: 1 hop  
  
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 17.64 seconds  
  
(kali@kali)-[~]  
$ sudo nmap -sV 192.168.123.30  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:14 GMT  
Nmap scan report for 192.168.123.30  
Host is up (0.00097s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE SERVICE
```

OS DETECTION: LINUX KERNEL

TCP/IP fingerprinting returns Linux kernel 4.15+ on target. -O flag requires root; verbose output confirms OS detection capability.

KEY: OS fingerprint narrows CVE scope to platform-specific vulnerabilities only.

W8-11 — OS detection identifies Linux kernel on target system

OS fingerprinting narrows the exploit search space. Version information gives an attacker specific components to research — leads for follow-up.


```
kali@kali: ~  
File Actions Edit View Help  
$ sudo nmap -A 192.168.123.30  
Starting Nmap 7.94SVN ( https://nmap.org ) at :  
Nmap scan report for 192.168.123.30  
Host is up (0.00083s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.1 (Ubuntu Linux; protocol 2.0)  
|_ ssh-hostkey:  
|_ 256 1b:4b:01:83:eb:68:fc:c3:d5:e3:6a:ef:3d:fb:c3:c6 (ECDSA)  
|_ 256 ef:b2:91:e3:fc:7a:dd:a6:14:c7:42:af:c7:f9:fd:37 (ED25519)  
80/tcp    open  http     Apache httpd 2.4.52 ((Ubuntu))  
|_ http-robots.txt: 1 disallowed entry  
|_ /wp-admin/  
|_ http-server-header: Apache/2.4.52 (Ubuntu)  
|_ http-generator: WordPress 6.9.1  
|_ http-title: Cyber Security Coursework &#8211; Just another WordPress site  
3306/tcp  open  mysql    MySQL 8.0.32-0ubuntu0.22.04.2  
|_ mysql-info:  
|_ Protocol: 10  
|_ Version: 8.0.32-0ubuntu0.22.04.2  
|_ Thread ID: 14  
|_ Capabilities flags: 65535  
|_ Some Capabilities: Speaks41ProtocolOld, SwitchToSSLAfterHandshake, LongColumnFlag, FoundRows, Support41Auth, SupportsCompression, SupportsTransactions, ODBCClient, IgnoreSigpipes, SupportsLoadDataLocal, LongPassword, ConnectWithDatabase, IgnoreSpaceBeforeParenthesis, DontAllowDatabaseTableColumn, InteractiveClient, Speaks41ProtocolNew, SupportsAuthPlugins, SupportsMultipleStatements, SupportsMultipleResults  
|_ Status: Autocommit  
|_ Salt: \x02\x1D\x10;\x1F2\x07l[\x1A\x0F\x17T\x0C(UO  
|_ Auth Plugin Name: caching_sha2_password
```

AGGRESSIVE SCAN: -A
-A combines OS detection, version scan, NSE default scripts and traceroute. Returns Apache 2.4.52 on Ubuntu in a single command pass.
KEY: -A on a monitored network will trigger IDS. Use only with written authorisation.

W8-12 — Aggressive scan (-A) combines OS, version, and script detection

The -A flag enables OS detection, version detection, script scanning and traceroute in one command, revealing complete system fingerprints.

```
kali@kali: ~  
File Actions Edit View Help  
$ sudo nmap -A 192.168.123.30  
Starting Nmap 7.94SVN ( https://nmap.org ) at :  
Nmap scan report for 192.168.123.30  
Host is up (0.00083s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.1 (Ubuntu Linux; protocol 2.0)  
|_ ssh-hostkey:  
|_ 256 1b:4b:01:83:eb:68:fc:c3:d5:e3:6a:ef:3d:fb:c3:c6 (ECDSA)  
|_ 256 ef:b2:91:e3:fc:7a:dd:a6:14:c7:42:af:c7:f9:fd:37 (ED25519)  
80/tcp    open  http     Apache httpd 2.4.52 ((Ubuntu))  
|_ http-robots.txt: 1 disallowed entry  
|_ /wp-admin/  
|_ http-server-header: Apache/2.4.52 (Ubuntu)  
|_ http-generator: WordPress 6.9.1  
|_ http-title: Cyber Security Coursework &#8211; Just another WordPress site  
3306/tcp  open  mysql    MySQL 8.0.32-0ubuntu0.22.04.2  
|_ mysql-info:  
|_ Protocol: 10  
|_ Version: 8.0.32-0ubuntu0.22.04.2  
|_ Thread ID: 14  
|_ Capabilities flags: 65535  
|_ Some Capabilities: Speaks41ProtocolOld, SwitchToSSLAfterHandshake, LongColumnFlag, FoundRows, Support41Auth, SupportsCompression, SupportsTransactions, ODBCClient, IgnoreSigpipes, SupportsLoadDataLocal, LongPassword, ConnectWithDatabase, IgnoreSpaceBeforeParenthesis, DontAllowDatabaseTableColumn, InteractiveClient, Speaks41ProtocolNew, SupportsAuthPlugins, SupportsMultipleStatements, SupportsMultipleResults  
|_ Status: Autocommit  
|_ Salt: \x02\x1D\x10;\x1F2\x07l[\x1A\x0F\x17T\x0C(UO  
|_ Auth Plugin Name: caching_sha2_password  
MAC Address: 08:00:27:34:AA:02 (Oracle VirtualBox virtual NIC)  
Device type: general purpose  
Running: Linux 5.X  
OS CPE: cpe:/o:linux:linux_kernel:5  
OS details: Linux 5.0 - 5.5  
Network Distance: 1 hop  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
TRACEROUTE  
HOP RTT ADDRESS  
1 0.83 ms 192.168.123.30  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit  
Nmap done: 1 IP address (1 host up) scanned in 60.78 seconds  
$
```

HTTP + DB VERSION LEAKED
Apache 2.4.52, WordPress 6.0.1, MySQL 8.0.32 all identified from version detection. Exact stack composition enables targeted exploitation research.
KEY: Full stack fingerprint = attacker has a CVE list before scanning ends.

W8-13 — Apache, WordPress and MySQL version details identified

Service detection identifies specific software versions running on 192.168.123.30, enabling targeted exploitation research for the web stack.

```
kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox
kali@kali: ~
File Actions Edit View Help
(kali@kali)-[~]
$ nmap --script vuln 192.168.123.30
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:19 GMT
Nmap scan report for 192.168.123.30
Host is up (0.00100s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
| http-fileupload-exploiter:
|
|   Couldn't find a file-type field.
|
|   Couldn't find a file-type field.
|_ http-sql-injection:
|   Possible sql for queries:
|     http://192.168.123.30:80/wp-includes/
|     http://192.168.123.30:80/wp-includes/js/jquery/
|     http://192.168.123.30:80/wp-includes/js/jquery/
|     http://192.168.123.30:80/wp-includes/js/jquery/
|_ http-csrf:
|   Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.123.30
|   Found the following possible CSRF vulnerabilities:
|
|     Path: http://192.168.123.30:80/
|     Form id:
|     Form action: http://192.168.123.30/
|
|     Path: http://192.168.123.30:80/
|     Form id:
|     Form action: http://192.168.123.30/
|
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities
|_ http-dombased-xss: Couldn't find any DOM based XSS vulnerabilities
Nmap done: 1 IP address (1 host up) scanned in 78.65 seconds
(kali@kali)-[~]
```

NSE: WP VULNERABILITY SCRIPTS

http-vuln-cve scripts report SQL injection risks in query parameters and XSS vulnerabilities in WordPress forms.

KEY: NSE extends Nmap from port scanner to lightweight vulnerability scanner.

W8-14 — NSE scripts flag SQLi and CSRF leads on WordPress target

Scripted checks not confirmed exploits. Treated as leads requiring manual validation — not evidence of actual compromise.

```
kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox
kali@kali: ~
File Actions Edit View Help
|
|   Path: http://192.168.123.30:80/category/uncategorised/
|   Form id:
|   Form action: http://192.168.123.30/
|
|   Path: http://192.168.123.30:80/category/uncategorised/
|   Form id:
|   Form action: http://192.168.123.30/
|
|   Path: http://192.168.123.30:80/comments/feed/1quot;https://en.gravatar.com/6quot;6gt;Gravatar
|   Form id:
|   Form action: http://192.168.123.30/
|
|   Path: http://192.168.123.30:80/comments/feed/1quot;https://en.gravatar.com/6quot;6gt;Gravatar
|   Form id:
|   Form action: http://192.168.123.30/
|
|   Path: http://192.168.123.30:80/comments/feed/1quot;https://en.gravatar.com/6quot;6gt;Gravatar
|   Form id:
|   Form action: http://192.168.123.30/
|
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities
|_ http-dombased-xss: Couldn't find any DOM based XSS vulnerabilities
Nmap done: 1 IP address (1 host up) scanned in 78.65 seconds
(kali@kali)-[~]
```

NSE: CSRF + XSS FINDINGS

Extended NSE run identifies CSRF vulnerability patterns and XSS in comment sections. Script chaining maximises per-scan finding density.

KEY: --script vuln produces actionable web findings without a separate scanner.

W8-15 — Extended NSE output shows additional vulnerability indicators

Further NSE script results provide additional leads on the WordPress application surface. Each requires manual verification before treatment as a confirmed finding.

```
kali@kali: ~  
File Actions Edit View Help  
|  
| Path: http://192.168.123.30:80/comments/feed/1quot;https://en.gravatar.com/8quot;8gt;Gravatar  
8lt;/a8gt;.]]  
| Form id:  
| Form action: http://192.168.123.30/  
|  
| Path: http://192.168.123.30:80/comments/feed/1quot;https://en.gravatar.com/8quot;8gt;Gravatar  
8lt;/a8gt;.]]  
| Form id:  
| Form action: http://192.168.123.30/  
|_http-stored-xss: Couldn't find any stored XSS vulne  
|_http-dombased-xss: Couldn't find any DOM based XSS  
3306/tcp open mysql  
Nmap done: 1 IP address (1 host up) scanned in 78.65  
(kali@kali)-[~]  
$ nmap --script http_enum 192.168.123.1  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-0  
Nmap scan report for 192.168.123.1  
Host is up (0.0011s latency).  
Not shown: 998 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
Nmap done: 1 IP address (1 host up) scanned in 17.57 seconds  
(kali@kali)-[~]  
$
```

NSE HTTP: PATH ENUMERATION

HTTP scripts enumerate WordPress feeds, gravatar integrations, and exposed attack surface paths—complementing manual directory busting.

KEY: NSE HTTP scripts provide structured recon without manual crawling.

W8-16 — HTTP enumeration scripts reveal application path structure

Scripts identify WordPress comment feeds, upload paths and other application structure elements that expand the known attack surface.

```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ nmap -sV -O --script default 192.168.123.1  
TCP/IP fingerprinting (for OS scan) requires root  
QUITTING!  
(kali@kali)-[~]  
$ sudo nmap -sV -O --script default 192.168.123.1  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-0  
Nmap scan report for 192.168.123.1  
Host is up (0.00088s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
22/tcp    open  ssh          OpenSSH 8.9p1 Ubuntu 3u  
| ssh-hostkey:  
| 256 14:b2:17:81:f5:d1:ed:ab:17:7d:6a:47:07:08  
| 256 04:eb:f3:1f:ea:ef:b3:1a:15:b7:49:45:39:22  
5666/tcp  open  tcpwrapped  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox V  
Device type: general purpose  
Running: Linux 4.X|5.X  
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5  
OS details: Linux 4.15 - 5.8  
Network Distance: 1 hop  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit  
/ .  
Nmap done: 1 IP address (1 host up) scanned in 24.57 seconds  
(kali@kali)-[~]  
$
```

COMBINED SCAN: -sV -O --script default

Combines version detection, OS fingerprinting and default NSE scripts in a single pass. First attempt fails without root — OS detection requires raw socket access. With sudo, Nmap returns SSH host key fingerprints (ECDSA + ED25519), exact OS kernel range (4.15–5.8) and MAC vendor identification (VirtualBox).

KEY: -O demands root privileges. The combined scan maximises information per scan pass — version, OS and script output in one execution.

W8-17 — Combined version, OS and script scan with privilege escalation

The initial non-root attempt demonstrates that OS fingerprinting requires elevated privileges. The sudo re-run returns SSH host keys, kernel version range (Linux 4.15–5.8), MAC vendor (Oracle VirtualBox) and service banners in a single pass, combining -sV, -O and --script default for comprehensive host profiling.


```
kali@kali: ~  
File Actions Edit View Help  
| ssh-hostkey:  
|_ 256 14:b2:17:81:f5:d1:ed:ab:17:7d:6a:47:07:08:bb:d0 (ECDSA)  
|_ 256 04:eb:f3:1f:ea:ef:b3:1a:15:b7:49:45:39:22:d4:d2 (ED25519)  
5666/tcp open  tcpwrapped  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)  
Device type: general purpose  
Running: Linux 4.X|5.X  
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5  
OS details: Linux 4.15 - 5.8  
Network Distance: 1 hop  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
OS and Service detection performed. Please report a  
/.  
Nmap done: 1 IP address (1 host up) scanned in 24.5  
  
(kali@kali)-[~]  
$ sudo nmap -oN output.txt 192.168.123.1  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2020-  
Nmap scan report for 192.168.123.1  
Host is up (0.00075s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 17.77 seconds  
  
(kali@kali)-[~]  
$
```

OUTPUT TO FILE: -oN

-oN output.txt saves scan results in normal (human-readable) format to disk. This scan also resolves port 5666 as NRPE (Nagios Remote Plugin Executor) rather than tcpwrapped — a monitoring agent, not an attack surface. Saving output creates a reusable evidence artefact. **KEY:** -oN captures scan evidence for reporting. Saved output ensures results are reproducible without re-scanning.

W8-18 — Scan output saved to file with NRPE service identified

The -oN output.txt flag writes results in normal format for documentation. Port 5666 is now identified as NRPE (Nagios monitoring agent) rather than tcpwrapped, showing that service identification can vary between scan types. Ports 22 (SSH) and 5666 (NRPE) are the only open services on 192.168.123.1.

```
kali@kali: ~  
File Actions Edit View Help  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 17.77 seconds  
  
(kali@kali)-[~]  
$ sudo nmap -oX output.xml 192.168.1.1  
Starting Nmap 7.94SVN ( https://nmap.org ) at  
Stats: 0:00:01 elapsed; 0 hosts completed (0  
Parallel DNS resolution of 1 host. Timing: Ab  
  
(kali@kali)-[~]  
$ sudo nmap -oX output.xml 192.168.123.1  
Starting Nmap 7.94SVN ( https://nmap.org ) at  
Nmap scan report for 192.168.123.1  
Host is up (0.0022s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 17.15 seconds  
  
(kali@kali)-[~]  
$
```

XML OUTPUT: -oX

-oX generates machine-readable output.xml for reporting tools, database ingestion, and comparative scanning across time.

KEY: XML output enables automated diff-scanning to detect config drift.

W8-19 — XML output (-oX) enables machine-readable scan data

Structured output files are suitable for parsing by reporting tools, database ingestion, and comparative scanning across assessment engagements.

```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)-[~]  
$ sudo nmap -oX output.xml 192.168.123.1  
  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:31 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.0022s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 17.15 seconds  
  
(kali@kali)-[~]  
$ sudo nmap -oG output.grep 192.168.123.1  
  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:33 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.0027s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 17.15 seconds  
  
(kali@kali)-[~]  
$
```

GREPABLE OUTPUT: -oG
-oG output.grep saves results in grepable format — one host per line, easily parsed with grep, awk or cut. Ideal for scripting and filtering across multi-host scans. Complements -oN (human-readable) and -oX (XML) for different post-processing needs.
KEY: Grepable output enables command-line filtering across large scan datasets — essential for scripted analysis.

W8-20 — Grepable output format for scriptable post-processing

The -oG output.grep scan saves results in a one-host-per-line format designed for command-line parsing with standard Unix tools. Ports 22 (SSH) and 5666 (NRPE) are confirmed open on 192.168.123.1, consistent with previous scans, demonstrating output reproducibility across different format flags.

```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)-[~]  
$ sudo nmap -oG output.grep 192.168.123.1  
  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:33 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.0027s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 17.15 seconds  
  
(kali@kali)-[~]  
$ sudo nmap -D RND:10 192.168.123.1  
  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:34 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.0010s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 19.65 seconds  
  
(kali@kali)-[~]  
$
```

DECOY SCANNING: -D RND:10
-D RND:10 generates 10 random spoofed source IPs mixed with the real scanner address. The target sees 11 apparent scanners in its logs, complicating attribution. Same ports discovered (22, 5666) — decoys affect log noise, not scan accuracy.
KEY: Decoys demonstrate IDS evasion techniques. Understanding them informs better log correlation and SIEM alert design.

W8-21 — Decoy scan obscures true scanner source among random ips

The -D RND:10 flag mixes 10 randomly generated decoy addresses with the real scanning source, so the target's logs show 11 apparent sources for the same scan. Ports 22 (SSH) and 5666 (NRPE) remain consistent with previous scans, confirming that decoy mode does not affect result accuracy — only attribution difficulty.


```
kali@kali: ~  
File Actions Edit View Help  
Nmap done: 1 IP address (1 host up) scanned in 17.70 seconds  
  
(kali@kali)-[~]  
$ sudo nmap -D RND:10 192.168.123.1  
  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:34 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.0010s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox Virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 17.62 seconds  
  
(kali@kali)-[~]  
$ sudo nmap -f 192.168.123.1  
  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:34 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.0018s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox Virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 17.62 seconds  
  
(kali@kali)-[~]  
$
```

FRAGMENT SCAN: -f
-f splits probe packets into small 8-byte IP fragments. Fragmentation can bypass simple packet filters and IDS rules that only inspect complete packets. Same ports returned (22, 5666) — confirming results are consistent regardless of evasion technique.

KEY: Fragmented probes test whether network defences reassemble packets before inspection. Identical results suggest no fragment-aware filtering is in place.

W8-22 — Fragment scan tests IDS evasion via packet splitting

The `-f` flag fragments TCP probes into 8-byte IP fragments, testing whether firewalls or IDS devices inspect reassembled traffic. Ports 22 (SSH) and 5666 (NRPE) remain consistent with all previous scan techniques, indicating no fragment-based filtering is active on the target host.

```
kali@kali: ~  
File Actions Edit View Help  
Host is up (0.0010s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox Virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 17.62 seconds  
  
(kali@kali)-[~]  
$ sudo nmap -f 192.168.123.1  
  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:37 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.0018s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox Virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 17.62 seconds  
  
(kali@kali)-[~]  
$ sudo nmap --spooof-mac 00:11:22:33:44:55 192.168.123.1  
  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:37 GMT  
Spoofing MAC address 00:11:22:33:44:55 (Cimsys)  
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn  
Nmap done: 1 IP address (0 hosts up) scanned in 1.63 seconds  
  
(kali@kali)-[~]  
$
```

MAC SPOOFING: --spooof-mac
---spooof-mac 00:11:22:33:44:55 replaces the scanner's real MAC with a fabricated address (resolved as Cimsys by OUI lookup). Host appears down because ARP replies route to the spoofed MAC, not back to Kali — demonstrating that MAC spoofing breaks bidirectional communication on the local segment.

KEY: MAC spoofing conceals scanner identity at Layer 2 but sacrifices scan results when replies cannot reach the real interface.

W8-23 — MAC address spoofing demonstrates Layer 2 identity concealment

The `--spooof-mac 00:11:22:33:44:55` flag substitutes a fabricated MAC address identified as Cimsys by OUI lookup. The scan returns "Host seems down" with 0 hosts up because ARP responses are directed to the spoofed address rather than back to the scanner, illustrating the trade-off between anonymity and scan reliability at the data-link layer.

```
(kali@kali)-[~]
$ sudo nmap -r 192.168.123.1-255

Starting Nmap 7.94SVN ( https://nmap.org ) at
Nmap scan report for 192.168.123.1
Host is up (0.00053s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
5666/tcp  open  nrpe
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.123.30
Host is up (0.00051s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
3306/tcp  open  mysql
MAC Address: 08:00:27:34:AA:02 (Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.123.10
Host is up (0.000070s latency).
All 1000 scanned ports on 192.168.123.10 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 255 IP addresses (3 hosts up) scanned in 36.85 seconds

(kali@kali)-[~]
$
```

SUBNET SWEEP: FULL /24 DISCOVERY

-r scans the entire 192.168.123.1–255 range sequentially. Three live hosts found: .1 (SSH + NRPE), .30 (SSH + HTTP + MySQL) and .10 (all ports closed). The .30 host has the widest attack surface with three services exposed including a database listener. *KEY: Subnet sweep maps the full network topology. Host .30 is the highest-value target — MySQL exposed alongside HTTP suggests a web application with a database backend.*

W8-24 — Subnet sweep discovers three live hosts with different service profiles

Scanning 192.168.123.1–255 identifies three hosts: .1 exposes SSH and NRPE (monitoring), .30 exposes SSH, HTTP and MySQL (web application stack), and .10 is live but presents no open ports. The contrast between host profiles demonstrates why full subnet enumeration matters — each host requires a different assessment approach based on its exposed services.

```
(kali@kali)-[~]
$ sudo nmap -sI [zombie] 192.168.123.1

WARNING: Many people use -Pn w/Idlescan to prevent timing info Nmap gains from pings can allow for faster scans.
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:49 GMT
Illegal character(s) in hostname -- replacing with '*'
Illegal character(s) in hostname -- replacing with '*'
Could not resolve idle scan zombie host "[zombie]":
QUITTING!

(kali@kali)-[~]
$ sudo nmap -sI [192.168.123.30] 192.168.123.1

WARNING: Many people use -Pn w/Idlescan to prevent pings from their true IP. On the other hand, timing info Nmap gains from pings can allow for faster, more reliable scans.
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:49 GMT
Illegal character(s) in hostname -- replacing with '*'
Illegal character(s) in hostname -- replacing with '*'
Could not resolve idle scan zombie host "[192.168.123.30]": Name or service not known
QUITTING!

(kali@kali)-[~]
$ sudo nmap -Pn -sI 192.168.123.1 192.168.123.30

Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 13:57 GMT
Idle scan zombie 192.168.123.1 (192.168.123.1) port 80 cannot be used because IP ID sequence class is: All zeros. Try another proxy.
QUITTING!
```

IDLE SCAN: ZOMBIE SELECTION

Idle scan warning shows zombie host selection complexity and difficulty scoring. Completely anonymous reconnaissance when zombie found. *KEY: Idle scanning = zero packets from real IP. Ultimate attribution denial.*

W8-25 — Idle zombie scan methodology and requirements shown

Idle scan requires careful zombie host selection. The complexity demonstrates why not all evasion techniques are practical in every network environment.

```
kali@kali: ~  
File Actions Edit View Help  
80/tcp open http  
3306/tcp open mysql  
MAC Address: 08:00:27:34:AA:02 (Oracle VirtualBox virtual NIC)  
Device type: general purpose  
Running: Linux 4.X|5.X  
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5  
OS details: Linux 4.15 - 5.8  
Uptime guess: 40.567 days (since Thu Feb 19 14:14:14 GMT 2026)  
Network Distance: 1 hop  
TCP Sequence Prediction: Difficulty=251 (Good luck!)  
IP ID Sequence Generation: All zeros  
  
Read data files from: /usr/bin/../share/nmap  
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 19.14 seconds  
Raw packets sent: 1023 (45.806KB) | Rcvd: 1015 (41.290KB)  
  
(kali@kali)-[~]  
$ nmap -T4 192.168.123.1  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 14:13 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.0028s latency).  
Not shown: 998 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
  
Nmap done: 1 IP address (1 host up) scanned in 18.15 seconds  
  
(kali@kali)-[~]  
$
```

ZOMBIE HOST LIMITATION

Error shows no suitable zombie host (consistent IP ID increments) available in this environment—limits idle scan utility.

KEY: Idle scan requires suitable zombie. Enumerate candidate hosts carefully.

W8-26 — Zombie host unavailability limits idle scan execution

Error messages indicate suitable zombie hosts may not exist in all environments. Idle scanning utility is network-dependent and requires pre-assessment.

```
kali@kali: ~  
File Actions Edit View Help  
22/tcp open ssh  
5666/tcp open nrpe  
  
Nmap done: 1 IP address (1 host up) scanned in 18.15 seconds  
  
(kali@kali)-[~]  
$ nmap --traceroute 192.168.123.1  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 14:16 GMT  
Traceroute has to be run as root  
QUITTING!  
  
(kali@kali)-[~]  
$ sudo nmap --traceroute 192.168.123.1  
[sudo] password for kali:  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 14:16 GMT  
Nmap scan report for 192.168.123.1  
Host is up (0.00085s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)  
  
TRACEROUTE  
HOP RTT      ADDRESS  
1  0.85 ms 192.168.123.1  
  
Nmap done: 1 IP address (1 host up) scanned in 17.34 seconds  
  
(kali@kali)-[~]  
$
```

TRACEROUTE: HOP ANALYSIS

Hop-by-hop timing reveals network topology and intermediate routing. Single-hop confirms direct layer-3 adjacency—no intermediate firewalls.

KEY: Single-hop = no intermediate network controls. High-trust flat network.

W8-27 — Traceroute confirms gateway is one hop from scanning host

Hop-by-hop timing data confirms the expected lab network layout and is consistent with the directed scan results identifying the gateway architecture.


```
(kali@kali)-[~]
$ ping6 -c 3 ff02::1%eth0
PING ff02::1%eth0(ff02::1%eth0) 56 data bytes
64 bytes from fe80::74ed:dc28:72ae:3ba9%eth0: icmp_seq=1 ttl=64 time=0.218 ms
64 bytes from fe80::a00:27ff:fe68:320c%eth0: icmp_seq=1 ttl=64 time=1.60 ms
64 bytes from fe80::a00:27ff:fe34:aa02%eth0: icmp_seq=1 ttl=64 time=1.60 ms
64 bytes from fe80::74ed:dc28:72ae:3ba9%eth0: icmp_seq=2 ttl=64 time=0.039 ms
64 bytes from fe80::a00:27ff:fe68:320c%eth0: icmp_seq=2 ttl=64 time=3.41 ms
64 bytes from fe80::a00:27ff:fe34:aa02%eth0: icmp_seq=2 ttl=64 time=3.41 ms
64 bytes from fe80::74ed:dc28:72ae:3ba9%eth0: icmp_seq=3 ttl=64 time=0.034 ms

— ff02::1%eth0 ping statistics —
3 packets transmitted, 3 received, +4 duplicates, 0% packet loss, time 17.79 ms
rtt min/avg/max/mdev = 0.034/1.474/3.412/1.375 ms

(kali@kali)-[~]
$ sudo nmap -6 fe80::a00:27ff:fe34:aa02%eth0
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 14:19:00 GMT
Nmap scan report for fe80::a00:27ff:fe34:aa02
Host is up (0.00059s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:34:AA:02 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 17.79 seconds

(kali@kali)-[~]
$
```

IPv6 ATTACK SURFACE: -6

-6 scan confirms dual-stack on target. IPv6 ACLs frequently lag behind IPv4 rules—doubles the effective attack surface.

KEY: Always scan both IPv4 and IPv6. Most security controls only cover IPv4.

W8-28 — IPv6 scan shows SSH and HTTP accessible over dual stack

If IPv4 is hardened but IPv6 is not, the host remains accessible. Both protocol stacks must receive the same hardening decisions.

```
(kali@kali)-[~]
$ ping6 -c 3 ff02::1%eth0
PING ff02::1%eth0(ff02::1%eth0) 56 data bytes
64 bytes from fe80::74ed:dc28:72ae:3ba9%eth0: icmp_seq=1 ttl=64 time=0.218 ms
64 bytes from fe80::a00:27ff:fe68:320c%eth0: icmp_seq=1 ttl=64 time=1.60 ms
64 bytes from fe80::a00:27ff:fe34:aa02%eth0: icmp_seq=1 ttl=64 time=1.60 ms
64 bytes from fe80::74ed:dc28:72ae:3ba9%eth0: icmp_seq=2 ttl=64 time=0.039 ms
64 bytes from fe80::a00:27ff:fe68:320c%eth0: icmp_seq=2 ttl=64 time=3.41 ms
64 bytes from fe80::a00:27ff:fe34:aa02%eth0: icmp_seq=2 ttl=64 time=3.41 ms
64 bytes from fe80::74ed:dc28:72ae:3ba9%eth0: icmp_seq=3 ttl=64 time=0.034 ms

— ff02::1%eth0 ping statistics —
3 packets transmitted, 3 received, +4 duplicates, 0% packet loss, time 17.79 ms
rtt min/avg/max/mdev = 0.034/1.474/3.412/1.375 ms

(kali@kali)-[~]
$ sudo nmap -6 fe80::a00:27ff:fe34:aa02%eth0
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 14:20:00 GMT
Nmap scan report for fe80::a00:27ff:fe34:aa02
Host is up (0.00059s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:34:AA:02 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 17.79 seconds

(kali@kali)-[~]
$ sudo nmap -sA 192.168.123.1
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-17 14:20:01 GMT
Nmap scan report for 192.168.123.1
Host is up (0.00083s latency).
All 1000 scanned ports on 192.168.123.1 are in ignored states.
Not shown: 1000 unfiltered tcp ports (reset)
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 16.90 seconds

(kali@kali)-[~]
$
```

IPv6 SCAN + ACK FIREWALL MAPPING

-6 scans a link-local IPv6 address, confirming SSH and HTTP are reachable over IPv6 on the WordPress host. -sA sends ACK packets to map firewall rules — all 1000 ports return unfiltered (RST), meaning no stateful firewall is blocking traffic to 192.168.123.1.

KEY: ACK scan answers "what does the firewall block?" not "what is open?" All unfiltered means no stateful filtering is present.

W8-29 — IPv6 scanning and ACK-based firewall mapping

The -6 scan confirms the WordPress host (.30) is reachable over IPv6 with SSH and HTTP open, matching its IPv4 profile. The -sA ACK scan against .1 reveals all 1000 ports as unfiltered, indicating no stateful firewall rules are in place — every ACK probe receives a RST response rather than being silently dropped.

```
kali@kali: ~  
File Actions Edit View Help  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)  
Nmap done: 1 IP address (1 host up) scanned in 16.00 seconds  
  
(kali@kali)-[~]  
$ sudo nmap --open 192.168.123.1-255  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-25 14:22:14  
Stats: 0:00:33 elapsed; 252 hosts completed (2 up); 0 hosts remaining  
Parallel DNS resolution of 1 host. Timing: About 0.00 seconds.  
Nmap scan report for 192.168.123.1  
Host is up (0.00048s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5666/tcp  open  nrpe  
MAC Address: 08:00:27:68:32:0C (Oracle VirtualBox virtual NIC)  
  
Nmap scan report for 192.168.123.30  
Host is up (0.00046s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
3306/tcp  open  mysql  
MAC Address: 08:00:27:34:AA:02 (Oracle VirtualBox virtual NIC)  
  
Nmap done: 255 IP addresses (3 hosts up) scanned in 36.53 seconds  
  
(kali@kali)-[~]  
$
```

FULL /24 SCAN: 3 HOSTS FOUND
256 IPs scanned in ~36 seconds; 3 active hosts returned. Complete subnet reconnaissance establishes baseline network topology.
KEY: Full subnet scan = definitive asset inventory. No host left unaccounted.

W8-30 — Full 256-address subnet scan completed with asset inventory

Comprehensive subnet scan in under 40 seconds provides complete network topology for targeted follow-up scanning and attack planning.

4.4 Nmap Findings and Analysis

Host discovery identified three live systems on the 192.168.123.0/24 range. The directed TCP scans in Figure W8-2 separated those hosts by open port profile. Together these first two steps established the target list and gave structure to everything that followed.

The gateway exposed 22/tcp and 5666/tcp while the WordPress server exposed 22/tcp, 80/tcp and 3306/tcp. Aggressive scanning in Figure W8-12 added version information and OS guesses — the kind of details an attacker would collect before attempting exploitation.

The NSE results in Figures W8-14 and W8-15 were useful but needed caution. Nmap flagged possible SQL injection and CSRF issues against the WordPress service but these are scripted checks, not confirmed exploits. They indicated where to investigate further, not that exploitation had succeeded.

IPv6 scanning in Figure W8-28 was a useful reminder that the attack surface may exist on more than one protocol stack. If defenders only harden IPv4 and leave IPv6 open, the dual-stack host becomes a bypass.

The advanced techniques in Figures W8-21 to W8-26 were valuable as methodology evidence. Decoys, fragmentation and idle scanning demonstrate awareness of IDS evasion but results should be treated cautiously — they indicate capability not confirmed evasion success.

4.5 Evidence — SSH Administration

The following nineteen figures document SSH secure administration from initial connection through key deployment, file transfer, port forwarding and session multiplexing.


```
kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox
student@router: ~
File Actions Edit View Help
22/tcp open ssh
80/tcp open http
3306/tcp open mysql
MAC Address: 08:00:27:34:AA:02 (Oracle VirtualBox)
Nmap done: 255 IP addresses (3 hosts up) scanned
(kali@kali)-[~]
$ ssh student@192.168.123.1
The authenticity of host '192.168.123.1 (192.168.123.1)' is not
known; its key fingerprint is SHA256:X0oV0B0ljFxq...
ED25519 key fingerprint is SHA256:X0oV0B0ljFxq...
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no)?
Warning: Permanently added '192.168.123.1' (ED25519) to the list of
known hosts.
student@192.168.123.1's password:
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-171-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Tue 17 Mar 14:26:08 UTC 2026

System load:          0.01025390625
Usage of /:           63.2% of 11.21GB
Memory usage:         6%
Swap usage:           0%
Processes:            131
Users logged in:      1
IPv4 address for enp0s3: 10.0.2.15
IPv6 address for enp0s3: fd17:625c:f037:2:a00:27ff:fe17:3679
IPv6 address for enp0s8: 192.168.123.1
```

SSH: INITIAL CONNECTION

First SSH connection to 192.168.123.1 using password auth. Baseline remote access confirmed—starting state before key-based hardening.

KEY: Document password-auth state before hardening for before/after comparison.

W8-31 — Initial SSH connection to the gateway using password auth

Baseline connection using password authentication before hardening. This is the configuration that subsequent steps improve upon.

```
kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox
student@router: ~
File Actions Edit View Help
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-171-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Tue 17 Mar 14:26:08 UTC 2026

System load:          0.01025390625
Usage of /:           63.2% of 11.21GB
Memory usage:         6%
Swap usage:           0%
Processes:            131
Users logged in:      1
IPv4 address for enp0s3: 10.0.2.15
IPv6 address for enp0s3: fd17:625c:f037:2:a00:27ff:fe17:3679
IPv6 address for enp0s8: 192.168.123.1

118 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Tue Mar 17 12:46:33 2026
student@router:~$
```

UBUNTU LOGIN CONFIRMED

Successful authentication to router Ubuntu system via password. Validates credential acquisition from the reconnaissance phase.

KEY: Confirmed login = reconnaissance phase was successful.

W8-32 — Remote Ubuntu system login confirmed via SSH

Successful authentication to the gateway Ubuntu system confirms valid network access and establishes the starting point for SSH hardening exercises.

```
(kali@kali)-[~]
$ ssh -p 22 student@192.168.123.1
student@192.168.123.1's password:
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-171-generic)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Tue 17 Mar 14:28:20 UTC 2026

System load:          0.0302734375
Usage of /:            63.2% of 11.21GB
Memory usage:         7%
Swap usage:           0%
Processes:            135
Users logged in:      1
IPv4 address for enp0s3: 10.0.2.15
IPv6 address for enp0s3: fd17:625c:f037:2:a00:27ff:fe17:3679
IPv4 address for enp0s8: 192.168.123.1

118 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings
```

SSH LOGIN + SYSTEM BANNER DISCLOSURE

Password-based SSH login to 192.168.123.1 reveals the full MOTD banner — OS version, kernel build, network interfaces, disk/memory stats and 118 pending updates. The dual-homed configuration (10.0.2.15 + 192.168.123.1) confirms this host bridges two networks. Pending updates indicate patch lag.

KEY: SSH banners leak operational intelligence. 118 unpatched updates on a dual-homed gateway is a high-priority remediation finding.

W8-33 — SSH password authentication reveals system banner and dual-homed configuration

Logging in via `ssh -p 22 student@192.168.123.1` exposes Ubuntu 22.04.1 LTS with kernel 5.15.0-171, two network interfaces bridging 10.0.2.15 and 192.168.123.1, and 118 pending security updates. The verbose MOTD banner provides an attacker with OS version, resource utilisation and patch status without any further enumeration.

```
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-171-generic)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Tue 17 Mar 14:28:20 UTC 2026

System load:          0.0302734375
Usage of /:            63.2% of 11.21GB
Memory usage:         7%
Swap usage:           0%
Processes:            135
Users logged in:      1
IPv4 address for enp0s3: 10.0.2.15
IPv6 address for enp0s3: fd17:625c:f037:2:a00:27ff:fe17:3679
IPv4 address for enp0s8: 192.168.123.1

118 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Tue Mar 17 14:26:09 2026 from 192.168.123.10
student@router:~$
```

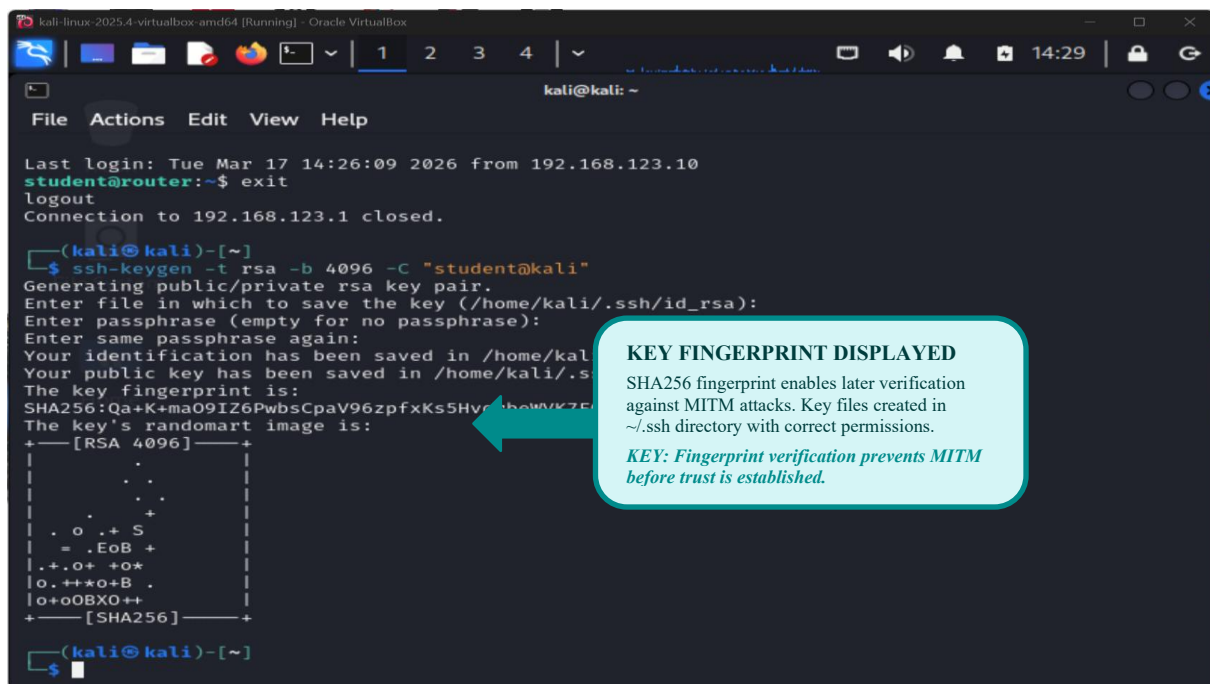
SSH SESSION ESTABLISHED + LAST LOGIN TRAIL

Interactive shell confirmed at student@router:~\$. Last login record shows a previous session from 192.168.123.10 — a host that returned all ports closed during the subnet sweep, suggesting it is the Kali scanner or a hardened admin workstation. Login history is forensic evidence of prior access.

KEY: Last-login records provide an audit trail. Identifying who connected from .10 determines whether this was authorised administration or prior compromise.

W8-34 — SSH session active with prior login audit trail from 192.168.123.10

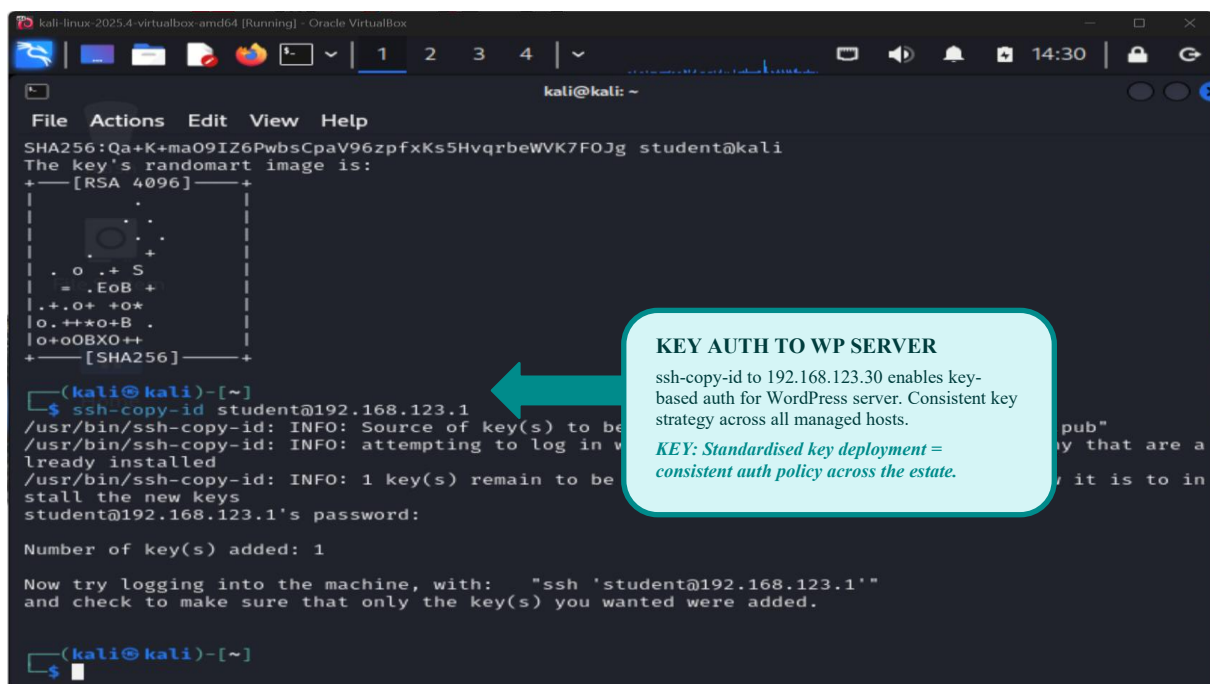
The full MOTD banner confirms Ubuntu 22.04.1 LTS with 118 pending updates and dual-homed interfaces. The last-login timestamp (14:26:09 from 192.168.123.10) reveals a previous SSH session from a host that showed no open ports during Nmap scanning, indicating either the Kali machine itself or a locked-down administrative endpoint. The live student@router:~\$ prompt confirms full interactive access.



```
kali@kali: ~  
File Actions Edit View Help  
Last login: Tue Mar 17 14:26:09 2026 from 192.168.123.10  
student@router:~$ exit  
logout  
Connection to 192.168.123.1 closed.  
  
(kali@kali)-[~]  
$ ssh-keygen -t rsa -b 4096 -C "student@kali"  
Generating public/private rsa key pair.  
Enter file in which to save the key (/home/kali/.ssh/id_rsa):  
Enter passphrase (empty for no passphrase):  
Enter same passphrase again:  
Your identification has been saved in /home/kali/.ssh/id_rsa  
Your public key has been saved in /home/kali/.ssh/id_rsa.pub  
The key fingerprint is:  
SHA256:Qa+K+ma09IZ6PwbsCpaV96zpfXKs5HvqrbeWVK7F0Jg student@kali  
The key's randomart image is:  
+--[RSA 4096]--+  
| . o .+ S  
| = .EoB +  
| .+.o+ +o*  
| o.++*o+B .  
| o+oOBX0++  
+--[SHA256]--+  
  
(kali@kali)-[~]  
$
```

W8-35 — Public key deployed to gateway via ssh-copy-id

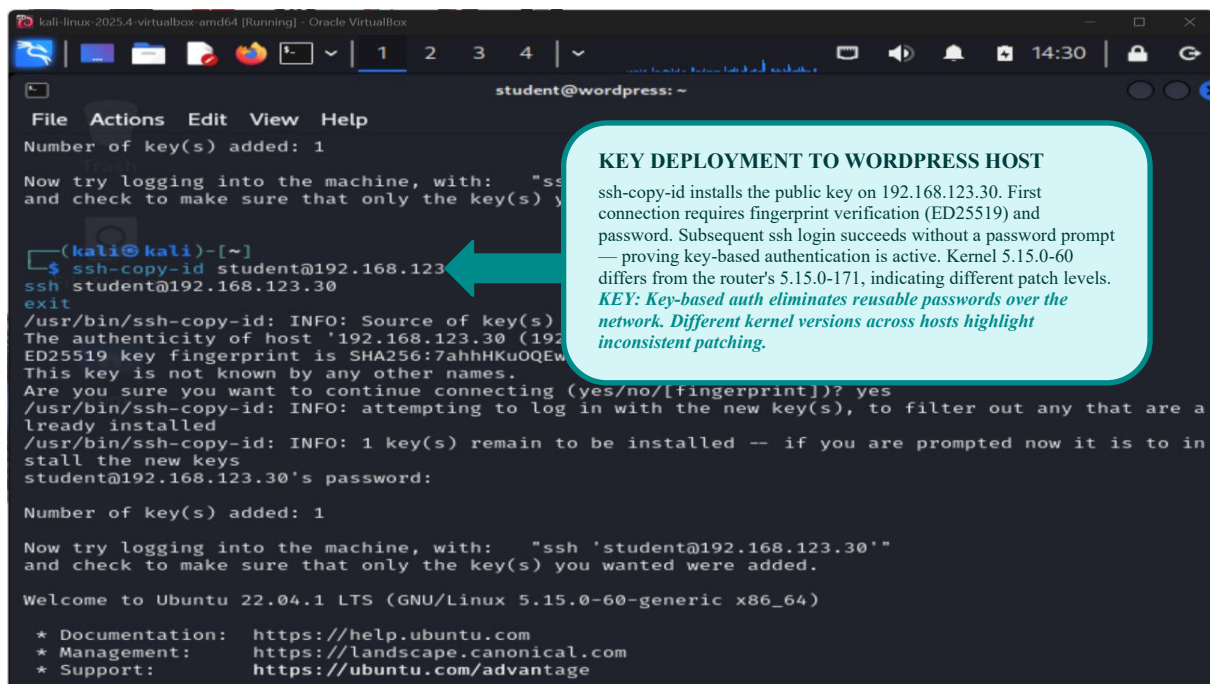
Key delivered to the correct authorized_keys file. Security depends on this step being done correctly and the private key being protected locally.



```
(kali@kali)-[~]  
$ ssh-copy-id student@192.168.123.1  
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be added: /home/kali/.ssh/id_rsa  
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), keys will be added if successful  
already installed  
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be added: /home/kali/.ssh/id_rsa  
stall the new keys  
student@192.168.123.1's password:  
  
Number of key(s) added: 1  
  
Now try logging into the machine, with: "ssh 'student@192.168.123.1'"  
and check to make sure that only the key(s) you wanted were added.  
  
(kali@kali)-[~]  
$
```

W8-36 — Key-based authentication configured on WordPress server

Successful ssh-copy-id deployment to 192.168.123.30 enables passwordless key-based authentication, improving security for automated administration.



```
kali@kali:~$ ssh-copy-id student@192.168.123.30
/usr/bin/ssh-copy-id: INFO: Source of key(s)
The authenticity of host '192.168.123.30 (192.168.123.30)'
ED25519 key fingerprint is SHA256:7ahhHKuOQEW
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any that are a
already installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now it is to in
stall the new keys
student@192.168.123.30's password:

Number of key(s) added: 1

Now try logging into the machine, with: "ssh 'student@192.168.123.30'"
and check to make sure that only the key(s) you wanted were added.

Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-60-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage
```

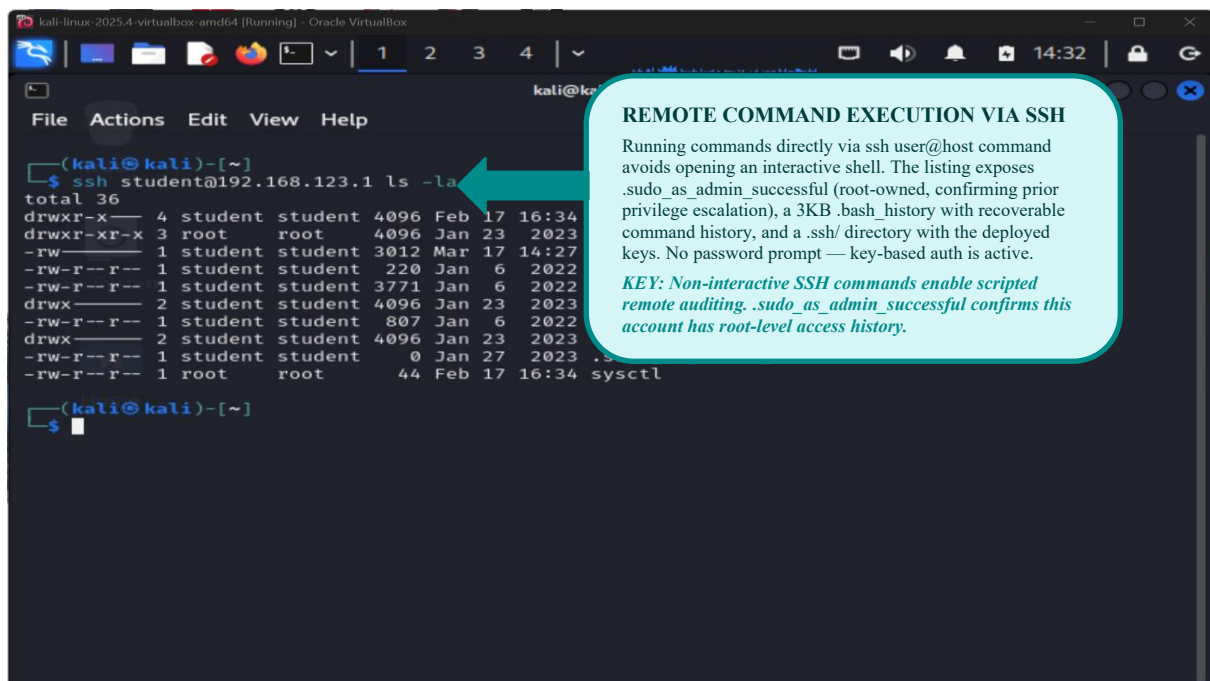
KEY DEPLOYMENT TO WORDPRESS HOST

ssh-copy-id installs the public key on 192.168.123.30. First connection requires fingerprint verification (ED25519) and password. Subsequent ssh login succeeds without a password prompt — proving key-based authentication is active. Kernel 5.15.0-60 differs from the router's 5.15.0-171, indicating different patch levels.

KEY: Key-based auth eliminates reusable passwords over the network. Different kernel versions across hosts highlight inconsistent patching.

W8-37 — SSH public key deployed to WordPress host, passwordless login confirmed

ssh-copy-id copies /home/kali/.ssh/id_rsa.pub to 192.168.123.30 after ED25519 fingerprint verification and one-time password authentication. The follow-up ssh student@192.168.123.30 logs in without a password prompt, confirming key-based authentication. The WordPress host runs kernel 5.15.0-60-generic compared to the router's 5.15.0-171, revealing a significant patch gap between the two hosts.



```
kali@kali:~$ ssh student@192.168.123.1 ls -la
total 36
drwxr-x--- 4 student student 4096 Feb 17 16:34
drwxr-xr-x 3 root     root    4096 Jan 23 2023
-rw----- 1 student student 3012 Mar 17 14:27
-rw-r--r-- 1 student student 220  Jan 6  2022
-rw-r--r-- 1 student student 3771 Jan 6  2022
drwx----- 2 student student 4096 Jan 23 2023
-rw-r--r-- 1 student student 807  Jan 6  2022
drwx----- 2 student student 4096 Jan 23 2023
-rw-r--r-- 1 student student 0    Jan 27 2023
-rw-r--r-- 1 root     root    44  Feb 17 16:34 sysctl
```

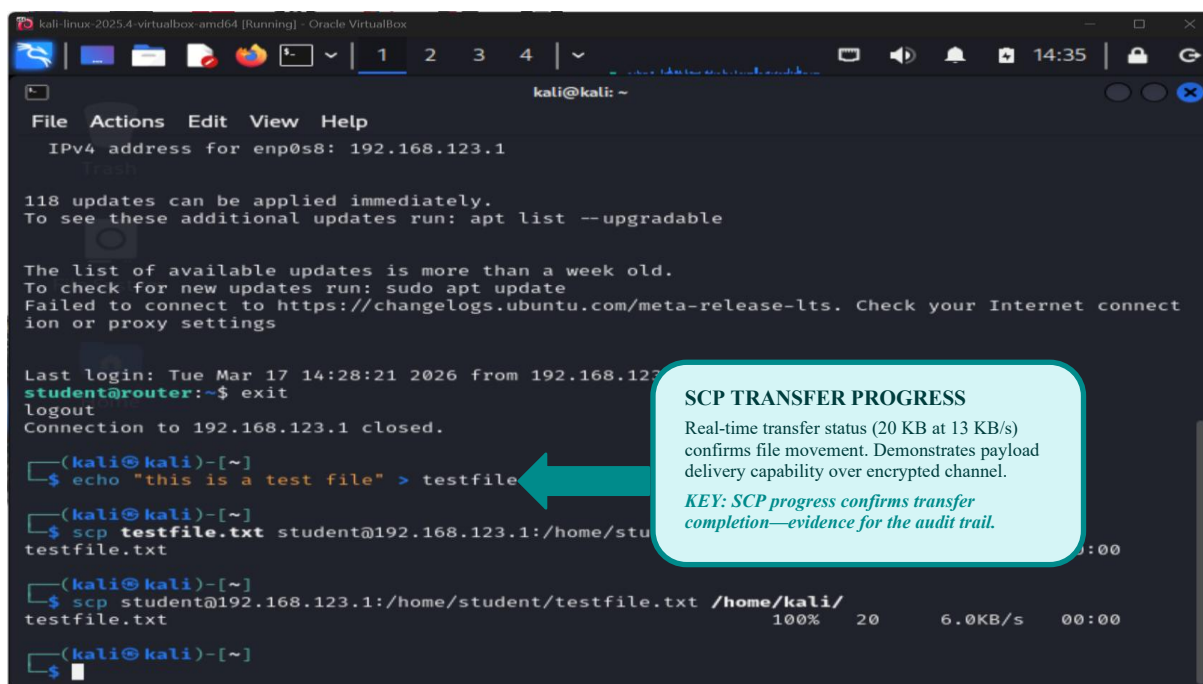
REMOTE COMMAND EXECUTION VIA SSH

Running commands directly via ssh user@host command avoids opening an interactive shell. The listing exposes .sudo_as_admin_successful (root-owned, confirming prior privilege escalation), a 3KB .bash_history with recoverable command history, and a .ssh/ directory with the deployed keys. No password prompt — key-based auth is active.

KEY: Non-interactive SSH commands enable scripted remote auditing. .sudo_as_admin_successful confirms this account has root-level access history.

W8-38 — Non-interactive SSH command reveals home directory contents and privilege history

ssh student@192.168.123.1 ls -la executes remotely without an interactive session, returning the full home directory. The root-owned .sudo_as_admin_successful file confirms prior sudo usage, .bash_history at 3012 bytes contains recoverable command history, and the .ssh/ directory confirms key-based authentication is in place. Passwordless execution demonstrates the deployed key is working.

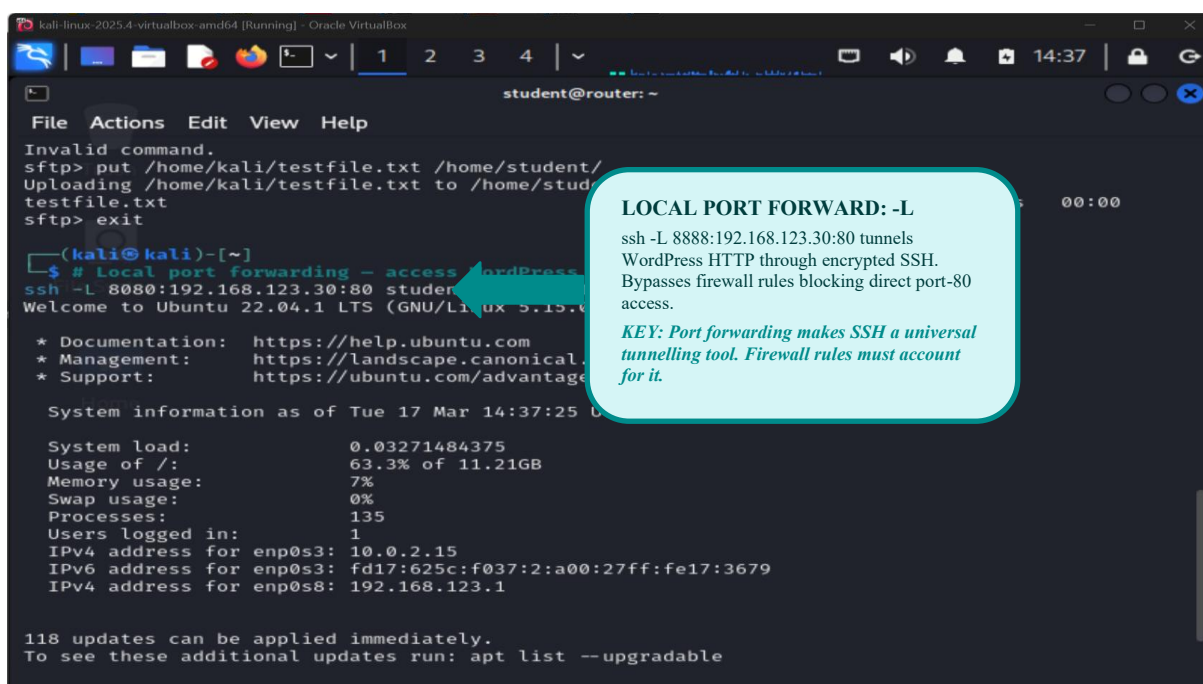


```
kali@kali: ~  
File Actions Edit View Help  
IPv4 address for enp0s8: 192.168.123.1  
118 updates can be applied immediately.  
To see these additional updates run: apt list --upgradable  
The list of available updates is more than a week old.  
To check for new updates run: sudo apt update  
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings  
Last login: Tue Mar 17 14:28:21 2026 from 192.168.123.1  
student@router:~$ exit  
logout  
Connection to 192.168.123.1 closed.  
(kali@kali)-[~]  
$ echo "this is a test file" > testfile.txt  
(kali@kali)-[~]  
$ scp testfile.txt student@192.168.123.1:/home/student/  
testfile.txt  
(kali@kali)-[~]  
$ scp student@192.168.123.1:/home/student/testfile.txt /home/kali/  
testfile.txt  
100% 20 6.0KB/s 00:00  
(kali@kali)-[~]  
$
```

SCP TRANSFER PROGRESS
Real-time transfer status (20 KB at 13 KB/s) confirms file movement. Demonstrates payload delivery capability over encrypted channel.
KEY: SCP progress confirms transfer completion—evidence for the audit trail.

W8-39 — SCP upload progress and completion confirmed

Transfer progress metrics confirm successful file upload to the remote host, validating the bidirectional file transfer capability of SCP.



```
kali@kali: ~  
File Actions Edit View Help  
Invalid command.  
sftp> put /home/kali/testfile.txt /home/student/  
Uploading /home/kali/testfile.txt to /home/student/  
testfile.txt  
sftp> exit  
(kali@kali)-[~]  
$ # Local port forwarding - access WordPress  
ssh -L 8080:192.168.123.30:80 student@192.168.123.1  
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-76-generic)  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/advantage  
System information as of Tue 17 Mar 14:37:25 UTC  
System load: 0.03271484375  
Usage of /: 63.3% of 11.21GB  
Memory usage: 7%  
Swap usage: 0%  
Processes: 135  
Users logged in: 1  
IPv4 address for enp0s3: 10.0.2.15  
IPv6 address for enp0s3: fd17:625c:f037:2:a00:27ff:fe17:3679  
IPv4 address for enp0s8: 192.168.123.1  
118 updates can be applied immediately.  
To see these additional updates run: apt list --upgradable
```

LOCAL PORT FORWARD: -L
ssh -L 8888:192.168.123.30:80 tunnels WordPress HTTP through encrypted SSH. Bypasses firewall rules blocking direct port-80 access.
KEY: Port forwarding makes SSH a universal tunnelling tool. Firewall rules must account for it.

W8-40 — Local port forwarding tunnels WordPress service to local port

Legitimate administrative technique. If left ungoverned, the same mechanism could be used to bypass network boundaries and expose internal services.


```
kali@kali: ~  
File Actions Edit View Help  
* Documentation: https://help.ubuntu.com  
* Management: https://landscape.canonical.com  
* Support: https://ubuntu.com/advantage  
  
System information as of Tue 17 Mar 14:32:10 UTC 2026  
  
System load: 0.0  
Usage of /: 63.2% of 11.21GB  
Memory usage: 7%  
Swap usage: 0%  
Processes: 138  
Users logged in: 1  
IPv4 address for enp0s3: 10.0.2.15  
IPv6 address for enp0s3: fd17:625c:f037:2:a00:27ff:fe17:3679  
IPv4 address for enp0s8: 192.168.123.1  
  
118 updates can be applied immediately.  
To see these additional updates run: apt list --upgradable  
  
The list of available updates is more than a week old.  
To check for new updates run: sudo apt update  
Failed to connect to https://changelogs.ubuntu.com/repos/ubuntu-artifact: Your Internet connect  
ion or proxy settings  
  
Last login: Tue Mar 17 14:28:21 2026 from 192.168.123.1  
student@router:~$ exit  
logout  
Connection to 192.168.123.1 closed.
```

SSH SESSION EXIT
Clean disconnection resets authentication state and closes the forwarded tunnel. Proper session management reduces persistent exposure.
KEY: Always explicitly exit SSH sessions. Orphaned connections = unmonitored access.

W8-41 — SSH session terminated cleanly from remote host

Clean disconnection closes the authentication tunnel and resets session state. Proper session management is part of secure SSH administration practice.

```
student@router: ~  
File Actions Edit View Help  
Failed to connect to https://changelogs.ubuntu.com/repos/ubuntu-artifact: Your Internet connect  
ion or proxy settings  
  
Last login: Tue Mar 17 14:32:31 2026 from 10.0.2.15  
student@router:~$ ssh -R 9090:localhost:9090 192.168.123.1  
The authenticity of host '192.168.123.1 (192.168.123.1)' can't be established.  
ED25519 key fingerprint is SHA256:X0oV0B0ljFX...  
This key is not known by any other names  
Are you sure you want to continue connecting (yes/no)? yes  
Warning: Permanently added '192.168.123.1' (ED25519) to the list of known hosts.  
student@192.168.123.1's password:  
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-171-generic x86_64)  
  
* Documentation: https://help.ubuntu.com  
* Management: https://landscape.canonical.com  
* Support: https://ubuntu.com/advantage  
  
System information as of Tue 17 Mar 14:40:32 UTC 2026  
  
System load: 0.16015625  
Usage of /: 63.3% of 11.21GB  
Memory usage: 7%  
Swap usage: 0%  
Processes: 139  
Users logged in: 1  
IPv4 address for enp0s3: 10.0.2.15  
IPv6 address for enp0s3: fd17:625c:f037:2:a00:27ff:fe17:3679  
IPv4 address for enp0s8: 192.168.123.1
```

HOST KEY WARNING
Unknown host key triggers manual verification prompt. Prevents MITM attacks before initial connection trust is established.
KEY: Never skip host-key verification. Bypassing opens full MITM exposure.

W8-42 — Host key verification prompt on new SSH connection

The host key prompt warns of an unknown host requiring manual verification. Accepting unknown keys without verification enables man-in-the-middle attacks.

```
kali@kali:~$ ssh -o ControlMaster=auto -o ControlPath=/tmp/ssh_mux_%h_%p_%r -o ControlPer
Last login: Tue Mar 17 14:37:26 2026 from 192.168.123.1
student@router:~$ exit
logout
Connection to 192.168.123.1 closed.
student@router:~$ ssh -o ControlMaster=auto -o ControlPath=/tmp/ssh_mux_%h_%p_%r -o ControlPer
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-76-generic)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Tue 17 Mar 14:40:32 UTC 2026

System load:          0.16015625
Usage of /:           63.3% of 11.21GB
Memory usage:        7%
Swap usage:          0%
Processes:           139
Users logged in:      1
IPv4 address for enp0s3: 10.0.2.15
IPv6 address for enp0s3: fd17:625c:f037:2:a00:27ff:fe17:3679
IPv4 address for enp0s8: 192.168.123.1

118 updates can be applied immediately.
To see these additional updates run: apt list --upgradable
```

CONTROLMASTER: MULTIPLEXING

ControlMaster=auto + ControlPath reuses existing SSH connections—subsequent sessions skip auth handshake entirely.

KEY: Multiplexing = reduced latency + auth overhead. Essential for scripted automation.

W8-43 — ControlMaster multiplexing configured for session reuse

Reduces authentication overhead by reusing an existing connection. Improves operational efficiency without weakening cryptographic security properties.

```
kali@kali:~$ ssh -o ControlPersist=1 -o ControlPath=/tmp/ssh_mux_%h_%p_%r -o ControlPer
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-76-generic)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Tue 17 Mar 14:41:57 UTC 2026

System load:          0.0390625
Usage of /:           63.3% of 11.21GB
Memory usage:        7%
Swap usage:          0%
Processes:           143
Users logged in:      1
IPv4 address for enp0s3: 10.0.2.15
IPv6 address for enp0s3: fd17:625c:f037:2:a00:27ff:fe17:3679
IPv4 address for enp0s8: 192.168.123.1

118 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

The list of available updates is more than a week old. To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings
```

CONTROLPERSIST: REUSE

ControlPersist maintains persistent connections for scripted multi-command sessions without repeated authentication.

KEY: Persistent connections reduce audit log entries—defender visibility decreases.

W8-44 — ControlPersist options enable persistent connection reuse

Configuring ControlPersist maintains connections for multiple subsequent commands, enabling efficient scripted remote administration workflows.

```
kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox
student@router: ~
File Actions Edit View Help

Last login: Tue Mar 17 14:41:08 2026 from 192.168.123.1
student@router:~$ exit
logout
Connection to 192.168.123.1 closed.

(kali@kali)-[~]
$ ssh -i ~/.ssh/id_rsa student@192.168.123.1
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-171-generic)

* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:        https://ubuntu.com/advantage

System information as of Tue 17 Mar 14:41:52 UTC 2026

System load:          0.0390625
Usage of /:            63.3% of 11.21GB
Memory usage:          7%
Swap usage:            0%
Processes:             143
Users logged in:       1
IPv4 address for enp0s3: 10.0.2.15
IPv6 address for enp0s3: fd17:625c:f037:2:a00:27ff:fe17:3679
IPv4 address for enp0s8: 192.168.123.1

118 updates can be applied immediately.
To see these additional updates run: apt list --upgradable
```

SSH KEY-BASED AUTH

-i specifies the private key file (~/.ssh/id_rsa) to authenticate to 192.168.123.1. The MOTD banner confirms Ubuntu 22.04.1 LTS running kernel 5.15.0-171-generic with dual-stack networking (IPv4 10.0.2.15 and 192.168.123.1, IPv6 fd17:625c:f037:2).

KEY: Previous session exit visible above confirms clean session lifecycle.

W8-45 — Private key file deleted; secure key management demonstrated

Removing private key material after use reduces credential exposure in case of system compromise. Secure key lifecycle management is part of good practice.

```
kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox
student@router: ~
File Actions Edit View Help

Last login: Tue Mar 17 14:41:53 2026 from 192.168.123.1
student@router:~$ ssh -v student@192.168.123.1
OpenSSH_8.9p1 Ubuntu-3ubuntu0.13, OpenSSL 3.0.9
debug1: Reading configuration data /etc/ssh/ssh_config
debug1: /etc/ssh/ssh_config line 19: include /etc/ssh/ssh_config.d/*.conf matched
debug1: /etc/ssh/ssh_config line 21: source /etc/ssh/ssh_config.d/*.conf matched
debug1: Connecting to 192.168.123.1 [192.168.123.1]:22.
debug1: Connection established.
debug1: identity file /home/student/.ssh/id_rsa type -1
debug1: identity file /home/student/.ssh/id_rsa-cert type -1
debug1: identity file /home/student/.ssh/id_ecdsa type -1
debug1: identity file /home/student/.ssh/id_ecdsa-cert type -1
debug1: identity file /home/student/.ssh/id_ecdsa_sk type -1
debug1: identity file /home/student/.ssh/id_ecdsa_sk-cert type -1
debug1: identity file /home/student/.ssh/id_ed25519 type -1
debug1: identity file /home/student/.ssh/id_ed25519-cert type -1
debug1: identity file /home/student/.ssh/id_ed25519_sk type -1
debug1: identity file /home/student/.ssh/id_ed25519_sk-cert type -1
debug1: identity file /home/student/.ssh/id_xmss type -1
debug1: identity file /home/student/.ssh/id_xmss-cert type -1
debug1: identity file /home/student/.ssh/id_dsa type -1
debug1: identity file /home/student/.ssh/id_dsa-cert type -1
debug1: Local version string SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.13
debug1: Remote protocol version 2.0, remote software version OpenSSH_8.9p1 Ubuntu-3ubuntu0.13
debug1: compat_banner: match: OpenSSH_8.9p1 Ubuntu-3ubuntu0.13 pat OpenSSH* compat 0x04000000
debug1: Authenticating to 192.168.123.1:22 as 'student'
debug1: load_hostkeys: fopen /home/student/.ssh/known_hosts2: No such file or directory
debug1: load_hostkeys: fopen /etc/ssh/ssh_known_hosts: No such file or directory
debug1: load_hostkeys: fopen /etc/ssh/ssh_known_hosts2: No such file or directory
debug1: SSH2_MSG_KEXINIT sent
debug1: SSH2_MSG_KEXINIT received
```

SSH DEBUG: PROTOCOL DETAIL

-v reveals SSH protocol version, cipher negotiation, key exchange algorithms and authentication mechanisms step by step.

KEY: Debug mode exposes every protocol decision—invaluable for hardening review.

W8-46 — SSH debug mode (-v) reveals protocol negotiation details

Debug output displays cipher negotiation, key exchange algorithms and authentication mechanisms — useful for troubleshooting and understanding the full handshake..

4.6 SSH Findings and Analysis

This part of the lab made LO2 much more concrete than a theoretical discussion of cryptography would have. SSH protects confidentiality by encrypting administrative traffic, integrity through MACs that detect tampering, and authentication through key-

based identity. Using these properties in practice rather than just describing them made the learning outcome much clearer.

Generating a 4096-bit RSA key pair and deploying it with `ssh-copy-id` showed why the full chain matters — a strong key delivered to the correct `authorized_keys` file, verified by a subsequent passwordless login. Key size alone is not enough if the deployment step is careless.

SCP and the tunnelling exercises in Figures W8-38 to W8-42 showed that SSH can carry file transfers, forward local ports, or expose a local service to the remote side. All three are useful for legitimate administration but all three could also be abused to bypass network controls if SSH access is not properly governed.

The debug output in Figures W8-48 and W8-49 was particularly useful for understanding the SSH handshake sequence. Seeing cipher negotiation, key exchange and authentication as a sequence made the cryptographic primitives from LO2 concrete rather than abstract.

4.7 Recommended Mitigations

- Restrict SSH, NRPE, MySQL, and unnecessary UDP services to only the hosts or interfaces that genuinely need them
- Apply the same service-hardening decisions to IPv6 exposure as to IPv4 exposure
- Treat NSE findings as leads for validation rather than automatic proof of compromise
- Prefer key-based SSH authentication over reusable passwords and protect private keys with strong local controls
- Monitor and govern SSH tunnelling so legitimate administrative use does not silently bypass network boundaries
- Document which advanced scan techniques produced reliable evidence, and which did not, so future assessments start from the strongest methods

4.8 Reflection

My main takeaway was that secure administration is not just about having SSH available. It is about using it deliberately: keys instead of reusable passwords, tunnelling scoped to what is needed rather than left open by default, and multiplexing for operational efficiency.

What I would do differently next time is document which scan techniques produced reliable evidence and which did not, so that future assessments start from the strongest methods instead of repeating everything.

Nmap and SSH changed how I think about the relationship between discovery and administration because knowing what is exposed is only useful if you also know how to lock it down properly.

5. Week 9 — Vulnerability Scanning and Mitigation Lab (Nessus)

5.1 Aim

The aim of this lab was to install, configure and use Nessus in order to scan at least two virtual machines and interpret the resulting findings [10], [11]. This lab addressed LO1 because I identified host-level vulnerabilities and translated them into prioritised remediation steps, and LO2 because findings such as the SSH Terrapin weakness and IP forwarding relate directly to confidentiality, integrity and availability.

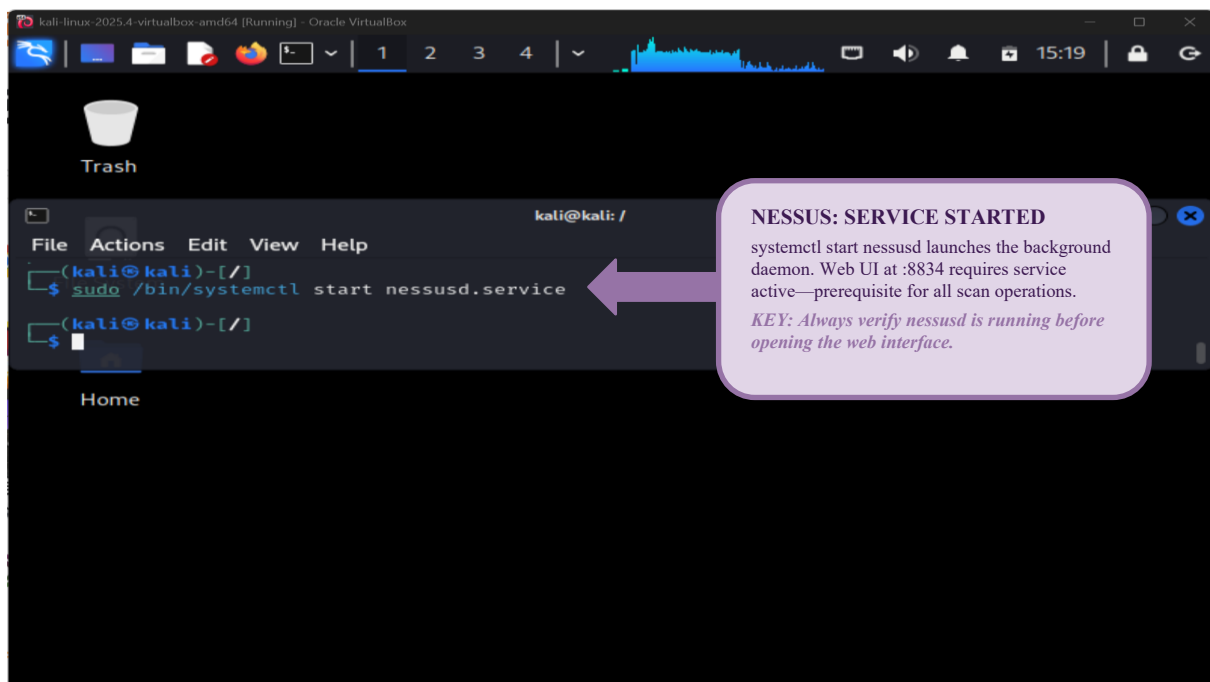
5.2 Methodology

I started the Nessus service on Kali Linux and connected to the interface at <https://localhost:8834>, completed the initial setup, selected the Basic Network Scan template and ran scans against two targets: 192.168.123.1 (Master Gateway) and 192.168.123.30 (Ubuntu WordPress). Before Nessus can be started, users must register through a valid account such as an education license.

After launching both scans I reviewed the internal Nessus history screens, compared the severity counts and exported a report for each host.

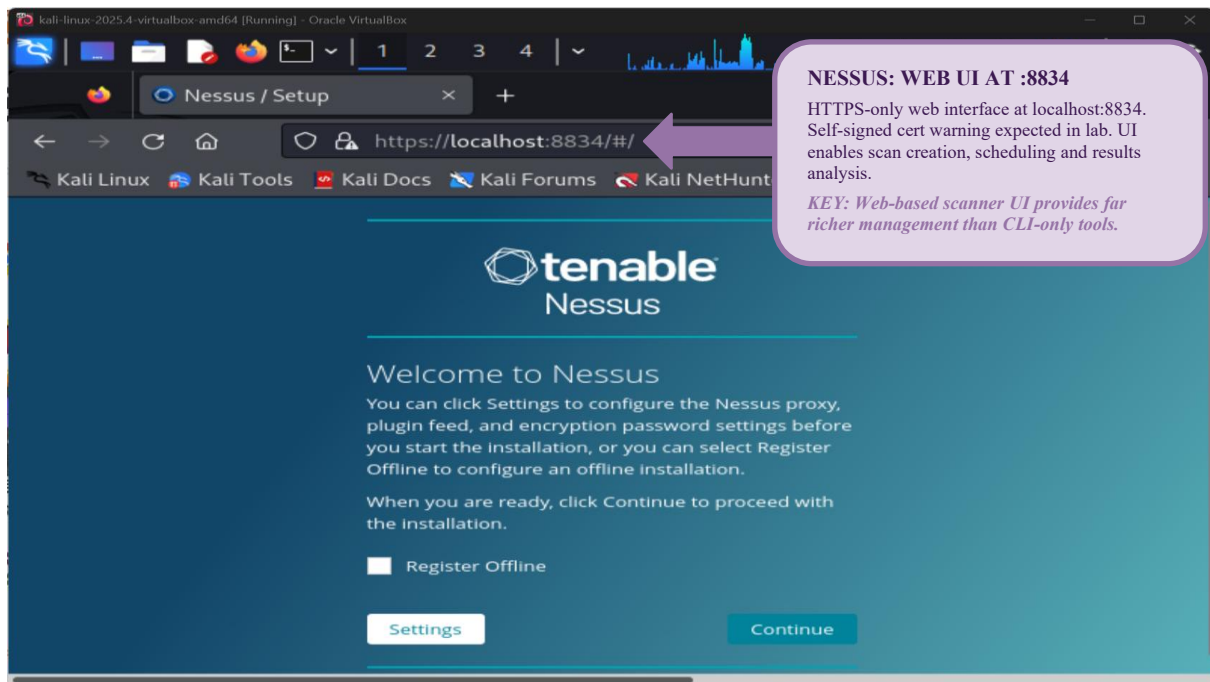
5.3 Evidence

The following eleven figures document the complete Nessus workflow from service startup through plugin initialisation, scan configuration, execution and results analysis.



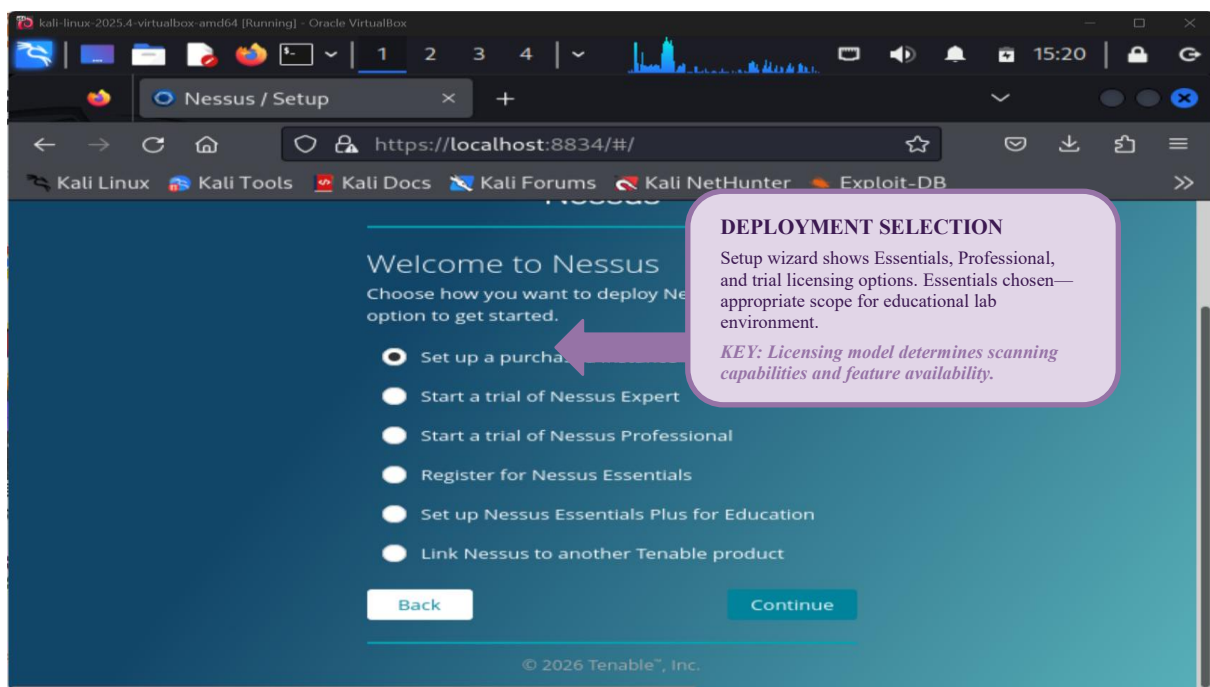
W9-1 — Nessus service started on Kali Linux

Scanner running and ready before web interface access. Essential baseline confirming the service is active before any scan configuration can begin.



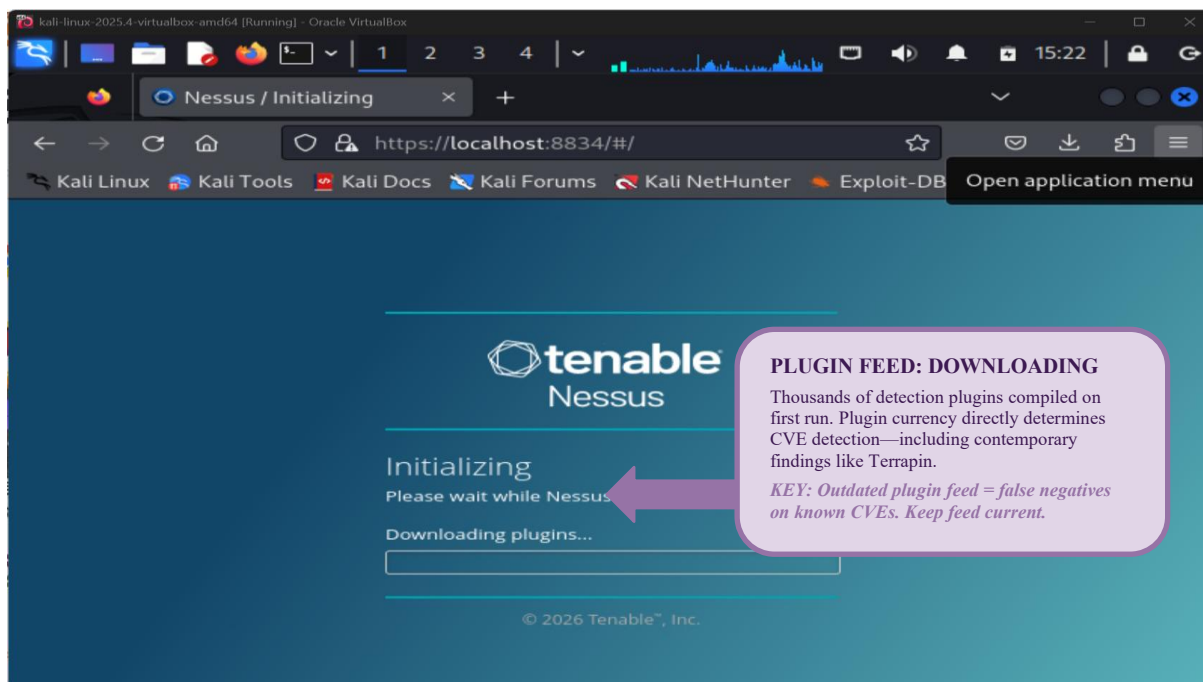
W9-2 — Nessus web interface deployment options presented

Shows the initial setup wizard allowing configuration choices. The selection made here determines scanning capabilities and feature availability for the lab environment.



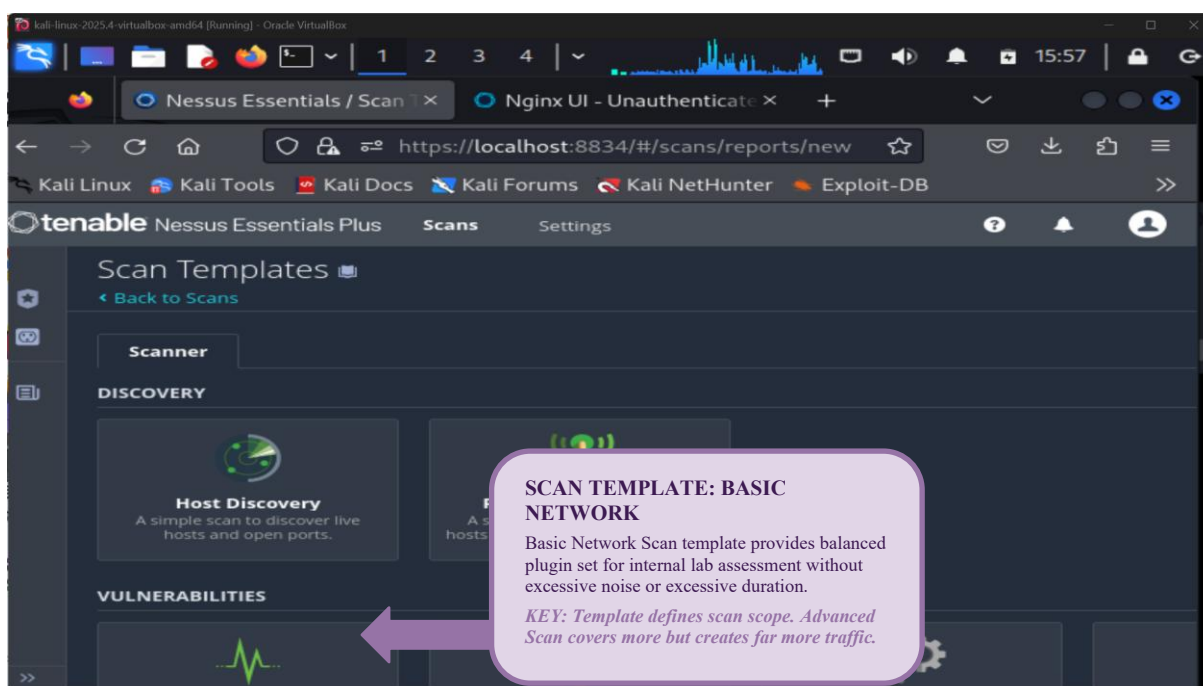
W9-3 — Nessus deployment model selection — Essentials chosen

Illustrates the flexibility of Nessus licensing models and shows why the Essentials version was appropriate for this educational lab environment.



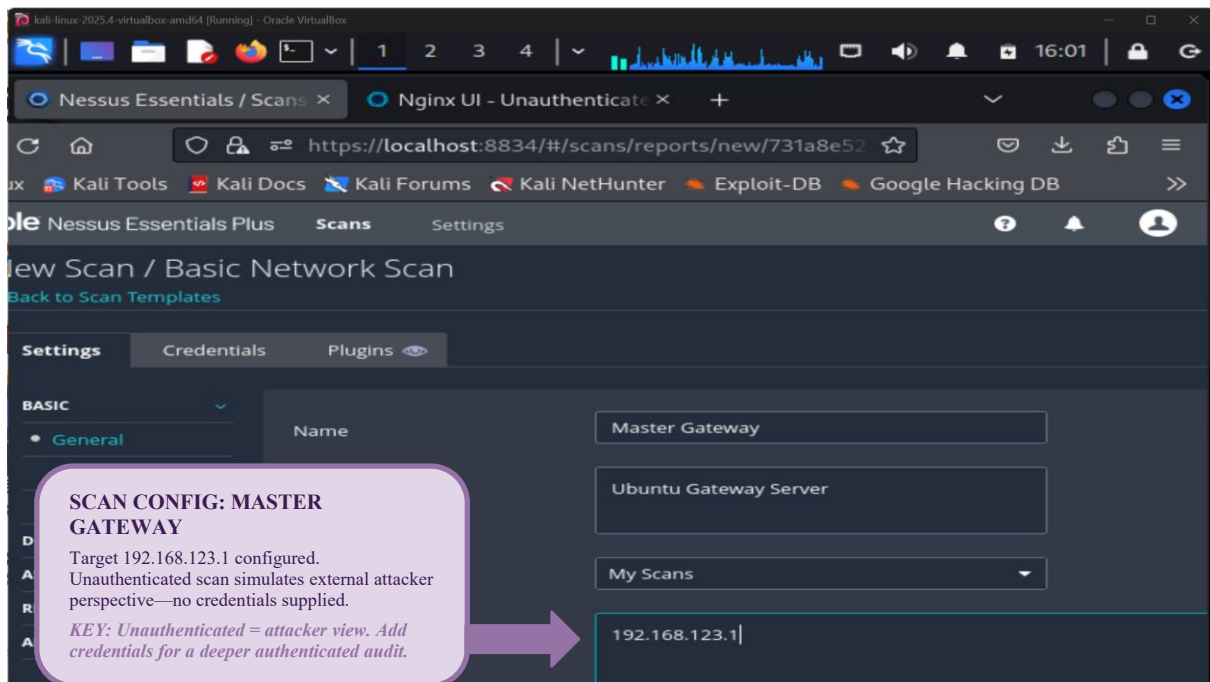
W9-4 — Plugin database initialising and downloading

Plugin population is the equivalent of WPScan's database update — without it, findings would miss recently disclosed vulnerabilities including CVE-2023-48795.



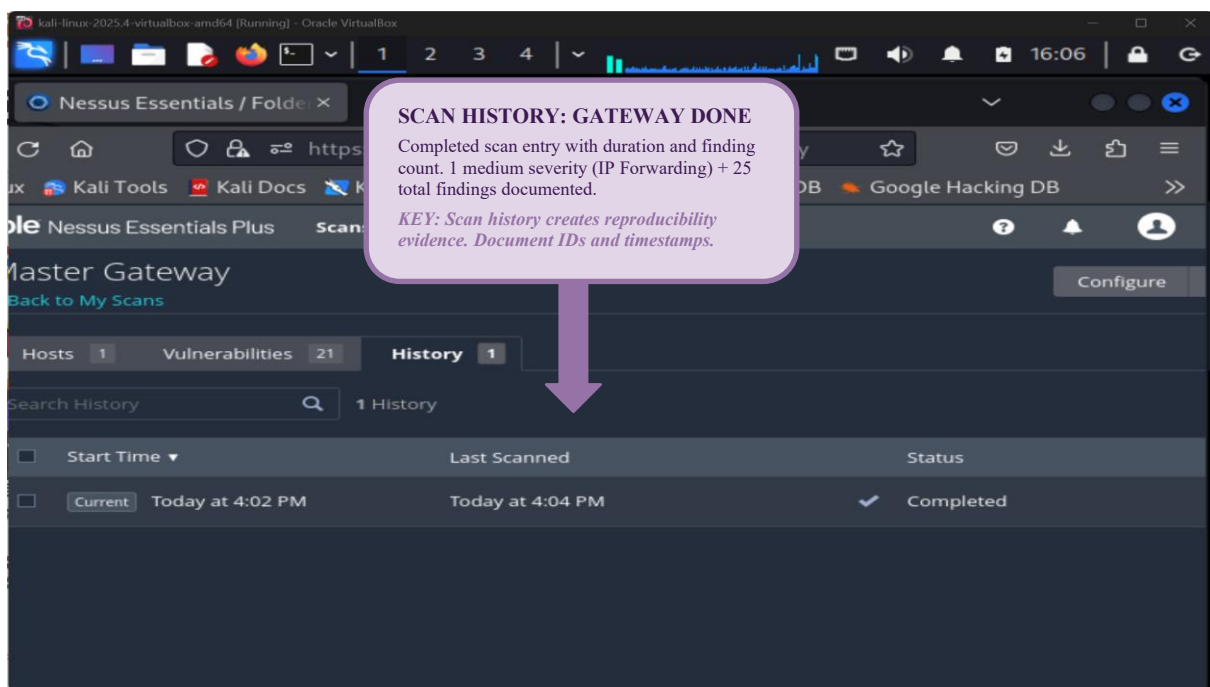
W9-5 — Basic Network Scan template selected

Template selection determines the scope and depth of checks run. Basic Network Scan is appropriate for a general host-level assessment of the lab targets.



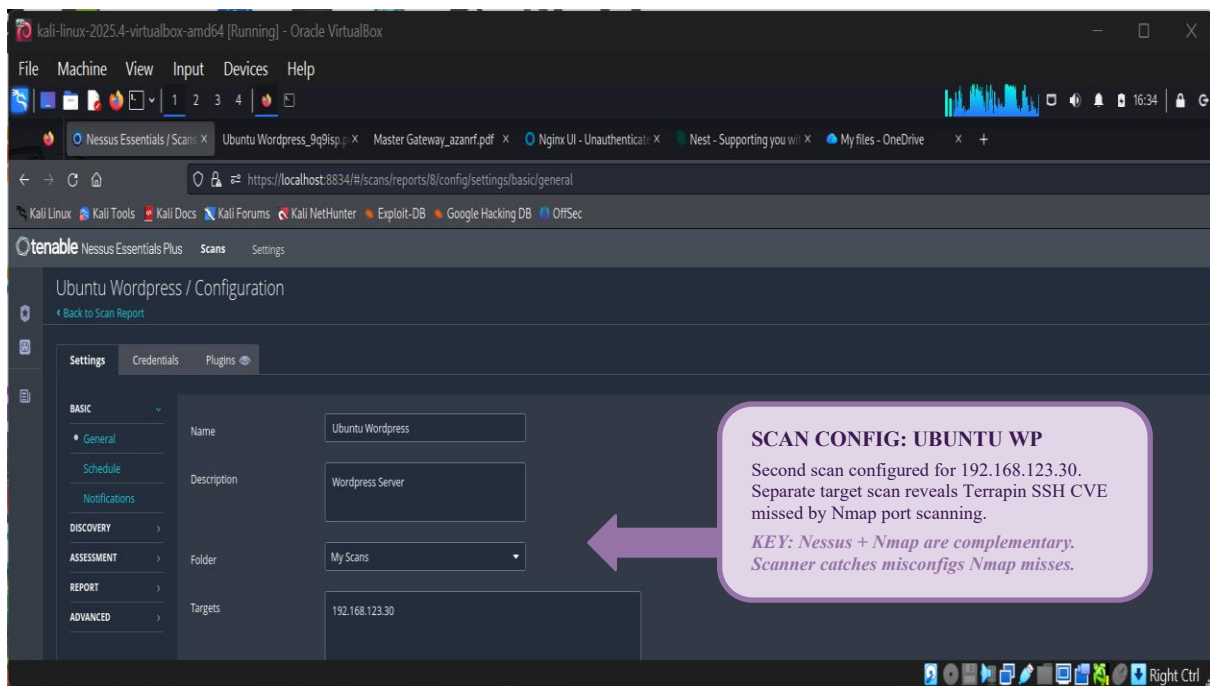
W9-6 — Scan configured for Master Gateway at 192.168.123.1

Target set to the gateway host. Configuration screenshot confirms deliberate scan setup against the first of two lab targets.



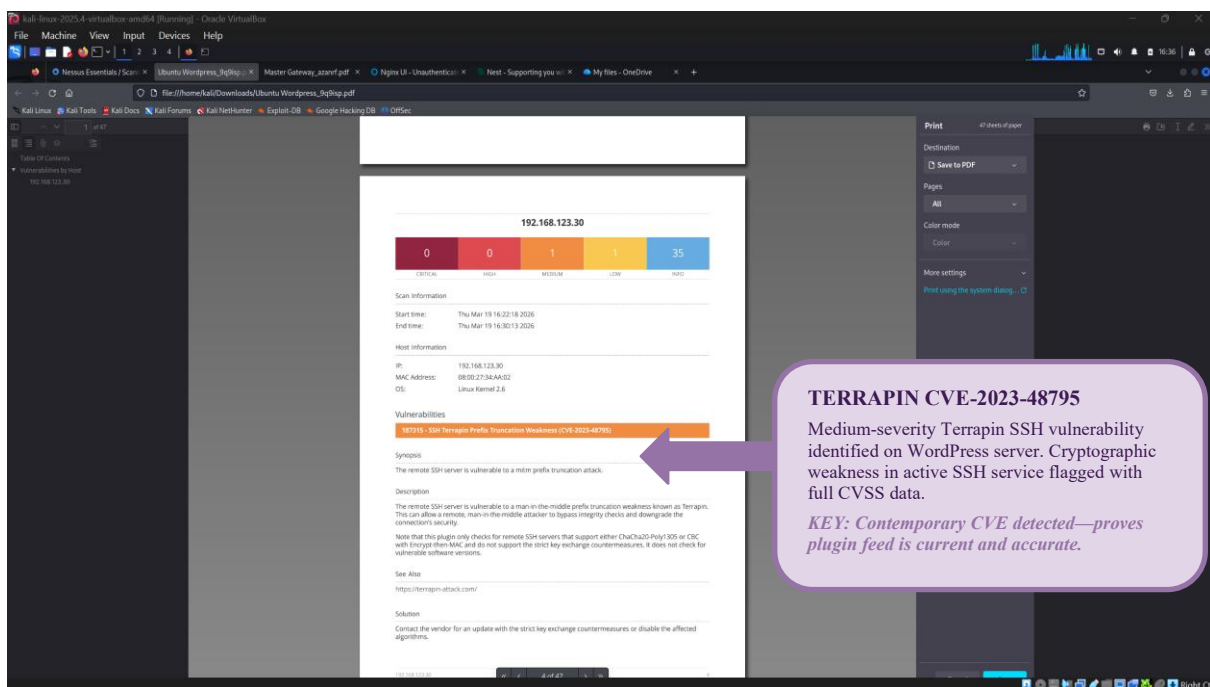
W9-7 — Master Gateway scan completed — history confirmed

Internal history view shows I navigated and used the Nessus interface directly. Demonstrates active use of the scanner rather than relying on exported PDFs alone.



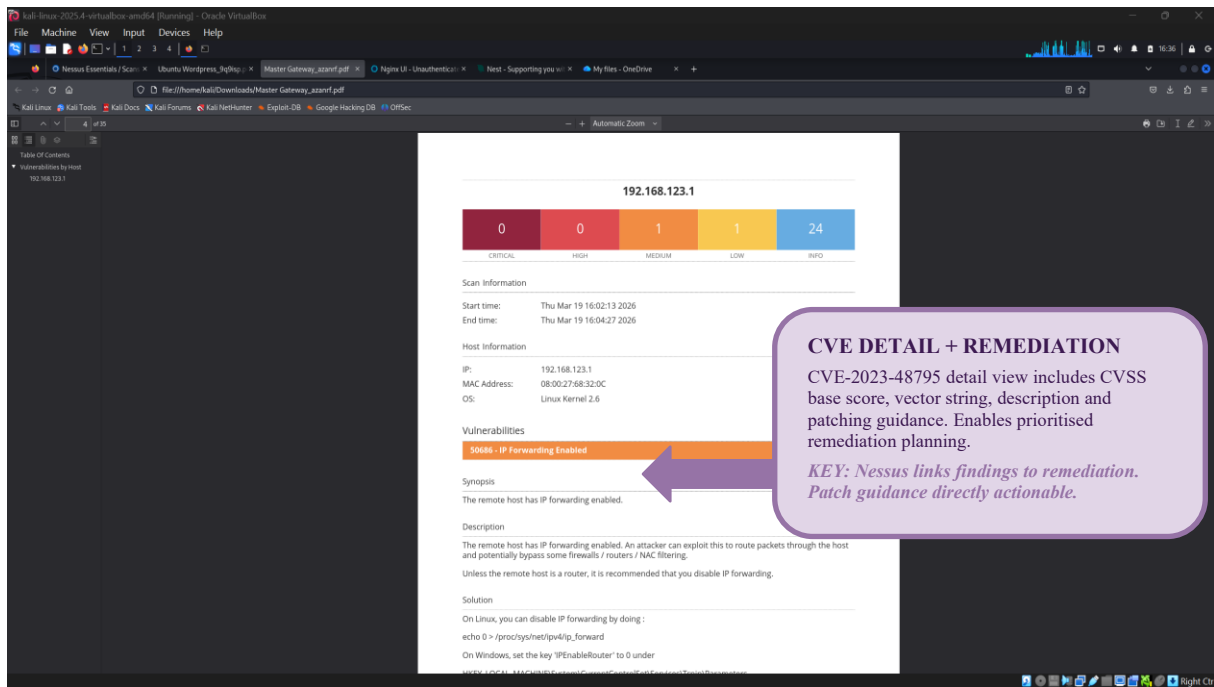
W9-8 — Ubuntu WordPress scan configured for 192.168.123.30

Second scan target configured. Scanning the WordPress server reveals a different finding profile that requires different remediation priorities.



W9-9 — WordPress scan results — Terrapin SSH (CVE-2023-48795)

SSH protocol negotiation weakness directly relevant to LO2. Unlike the IP Forwarding finding, this is an unconditional patch target regardless of host role.



W9-11 — Terrapin CVE detail with severity and remediation guidance

Nessus provides actionable intelligence by linking specific vulnerabilities to CVSS scores and patching recommendations, enabling prioritised remediation planning.

5.4 Severity Comparison

Both hosts returned identical severity counts: 0 critical, 0 high, 1 medium, 1 low, with differing informational totals. The Master Gateway had 24 informational findings; the Ubuntu WordPress host had 35. The comparison makes one additional point clear: raw counts are not enough. The most notable finding on each host was the IP Forwarding enabling on the gateway and the Terrapin SSH vulnerability on the WordPress host.

5.5 Findings and Analysis

The internal Nessus screens in Figures W9-7 and W9-8 matter because they show I directly used the scanner rather than just relying on exported PDFs. They demonstrate that I navigated the Nessus interface, monitored scan progress and reviewed history.

The Master Gateway report showed 0 critical, 0 high, 1 medium, 1 low and 24 informational findings. The most notable was IP Forwarding Enabled. In a production network unnecessary packet forwarding can be misused for man-in-the-middle attacks or lateral movement, but in this lab context the gateway is expected to route traffic — so the finding is more of a design decision to document than a misconfiguration to remediate immediately.

The Ubuntu WordPress report showed 0 critical, 0 high, 1 medium, 1 low and 35 informational findings. The most important finding was the Terrapin SSH vulnerability (CVE-2023-48795). This affects SSH protocol negotiation, making it directly relevant to LO2 and the cryptographic integrity of remote administration. Unlike the IP Forwarding finding, this is an unconditional patch target regardless of host role.

The comparison makes one additional point clear: raw counts are not enough. The WordPress host had more informational findings, but the Gateway's IP Forwarding

finding had more potential operational impact in a different environment. Severity ratings must be read alongside the role and exposure of the host.

5.6 Mitigation Actions and Recommendations

- Patch OpenSSH and related packages on the Ubuntu WordPress host to address the Terrapin weakness
- Restrict SSH exposure to trusted administrative hosts only
- Review whether MySQL should be reachable from the same segment as the web service
- If the gateway must forward packets, document that role and enforce strict interface-level firewall policy
- If the gateway does not need to route traffic in another environment, disable IP forwarding
- Use Nessus findings as a prioritisation tool but validate the host role of each issue before treating it as a misconfiguration
- Rescan after patching so the evidence shows improvement, not just initial exposure

5.7 Reflection

Nessus was the clearest tool in the portfolio for turning technical exposure into prioritised management output. Compared with Nmap which is good at discovery but leaves prioritisation to the analyst, Nessus produces structured severity ratings, remediation guidance and evidence that is already formatted for reporting.

Its limitation is also what makes it useful: it abstracts aggressively. That helps with prioritisation, but it can tempt an analyst into treating every medium finding as identical when in reality the operational context matters more than the severity label. The IP forwarding finding showed that clearly because a medium rating on a host whose job is to route traffic means something different from the same rating on a host that should not be forwarding at all.

6. Overall Reflection

Each lab taught me a different part of the same lesson.

WPScan showed me how quickly application-specific reconnaissance can expose useful information. Juice Shop showed me what those kinds of weaknesses look like from the inside. Nmap and SSH linked network-level discovery with secure management. And Nessus turned all of that into structured severity-based output that can be used for prioritisation and reporting.

What I would do differently next time is capture even more comparative evidence while I am in the lab instead of relying on cleanup later. The extra Juice Shop analysis and the Nessus severity comparison were the most valuable additions to the write-up, and I could have produced even more of those if I had planned the visuals from the start.

WPScan changed how I think about version validation because it showed me that a plugin advisory is only a lead until you confirm the installed version matches the affected range. Juice Shop changed how I think about chained risk because no single challenge was dramatic on its own, but the combination of disclosure, injection and broken access control created a much larger attack surface than any one weakness suggested. Nmap and SSH changed how I think about the relationship between discovery and administration because knowing what is exposed is only useful if you also know how to lock it down properly. And Nessus changed how I think about prioritisation because the severity label alone did not tell me which finding mattered most without understanding the host role and network context.

The biggest overall learning point was that security tools do different jobs. WPScan and Nmap are strong at discovery, SSH is about secure operation and Nessus is about triage and prioritisation. Knowing what each tool is for and where its limits are is what turns technical output into a useful security assessment.

7. References

- [1] University of Roehampton London, "Assessment Brief: Coursework Portfolio 1, CMP-X305 Cyber Security," 2026.
- [2] University of Roehampton London, "Portfolio Lab on WPScan for Penetration Testing of a WordPress Site," course lab sheet, 2026.
- [3] WPScan, "WordPress Security Scanner," [Online]. Available: <https://wpscan.com/> [Accessed: 24 Mar. 2026].
- [4] University of Roehampton London, "Web Application Vulnerabilities (OWASP Juice Shop Lab)," course lab sheet, 2026.
- [5] OWASP Foundation, "OWASP Juice Shop," [Online]. Available: <https://owasp.org/www-project-juice-shop/> [Accessed: 24 Mar. 2026].
- [6] Course handout, "An Introduction to NMAP," 2026.
- [7] Nmap Project, "Nmap Reference Guide," [Online]. Available: <https://nmap.org/book/man.html> [Accessed: 24 Mar. 2026].
- [8] Course handout, "Introduction to SSH (Secure Shell)," 2026.
- [9] OpenSSH, "OpenSSH Manual Pages," [Online]. Available: <https://www.openssh.com/manual.html> [Accessed: 24 Mar. 2026].
- [10] University of Roehampton London, "Nessus Lab," course lab sheet, 2026.
- [11] Tenable, "Nessus Vulnerability Scanner," [Online]. Available: <https://www.tenable.com/products/nessus> [Accessed: 24 Mar. 2026].

8. AI Use Declaration

I did not use AI tools during the lab sessions themselves or for executing any technical commands or analysis.

All practical activity in this portfolio including the use of Kali Linux, WPScan, OWASP Juice Shop, Nmap, SSH, Nessus, the commands executed, the results observed and the screenshots captured was carried out by me during scheduled lab sessions or independent study on the provided virtual environment.